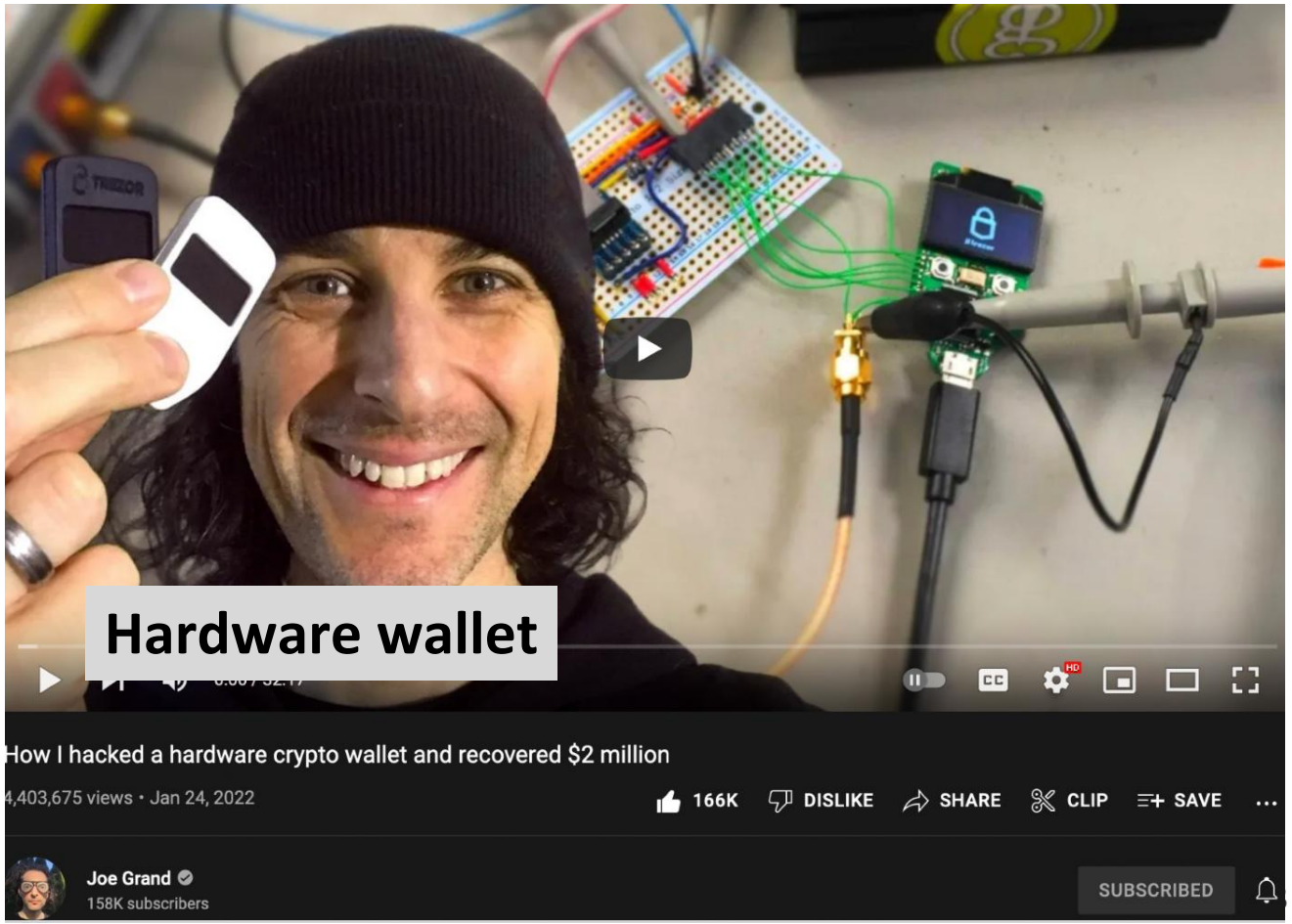
Physical Attacks

Vincent Ulitzsch <viniul@mit.edu>

Spring 2026

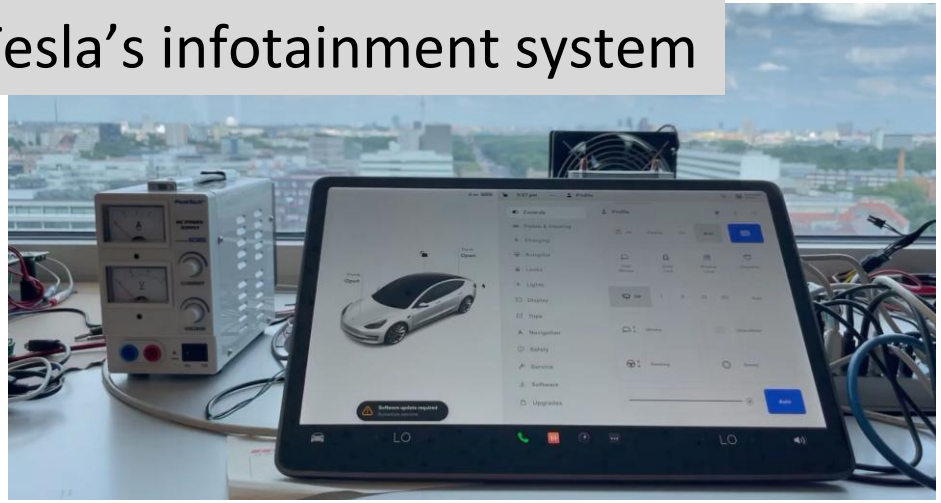
Assume an attacker has physical access to the computing device ---- What attacks are possible?

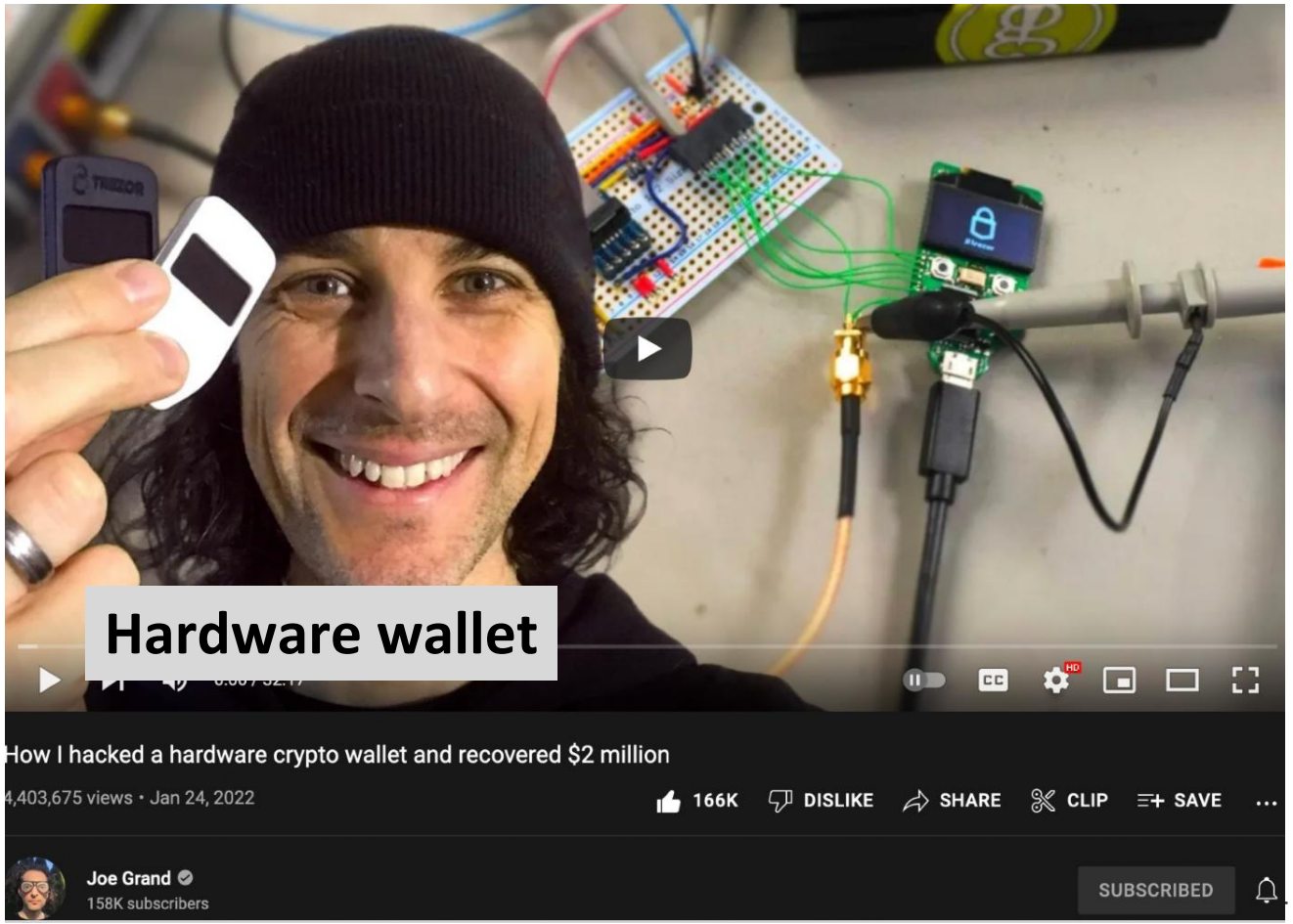
Physical Attacks Were Used In Many Real-World Attacks



Physical Attacks Were Used In Many Real-World Attacks

Tesla's infotainment system





Physical Attacks Were Used In Many Real-World Attacks

One Glitch to Rule Them All: Fault Injection Attacks Against AMD's Secure Encrypted Virtualization

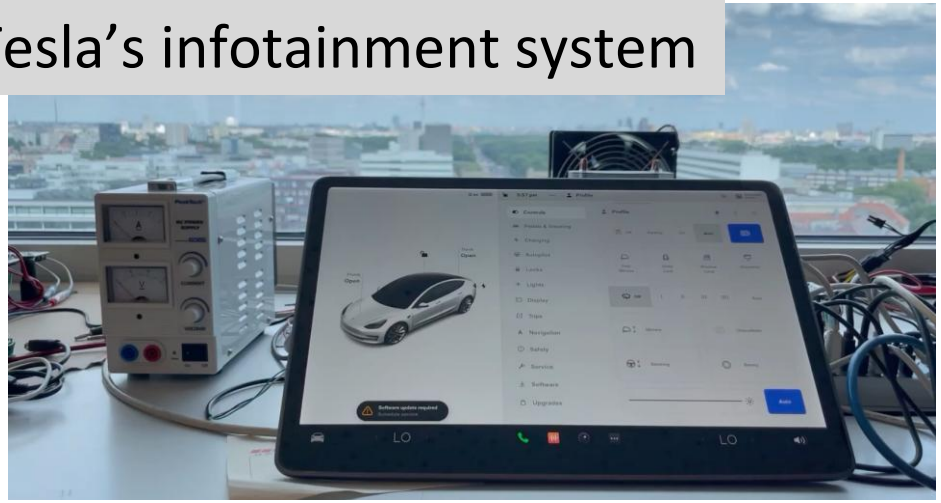
Robert Buhren
robert.buhren@sect.tu-berlin.de
Tec
Technische Universität Berlin - SECT

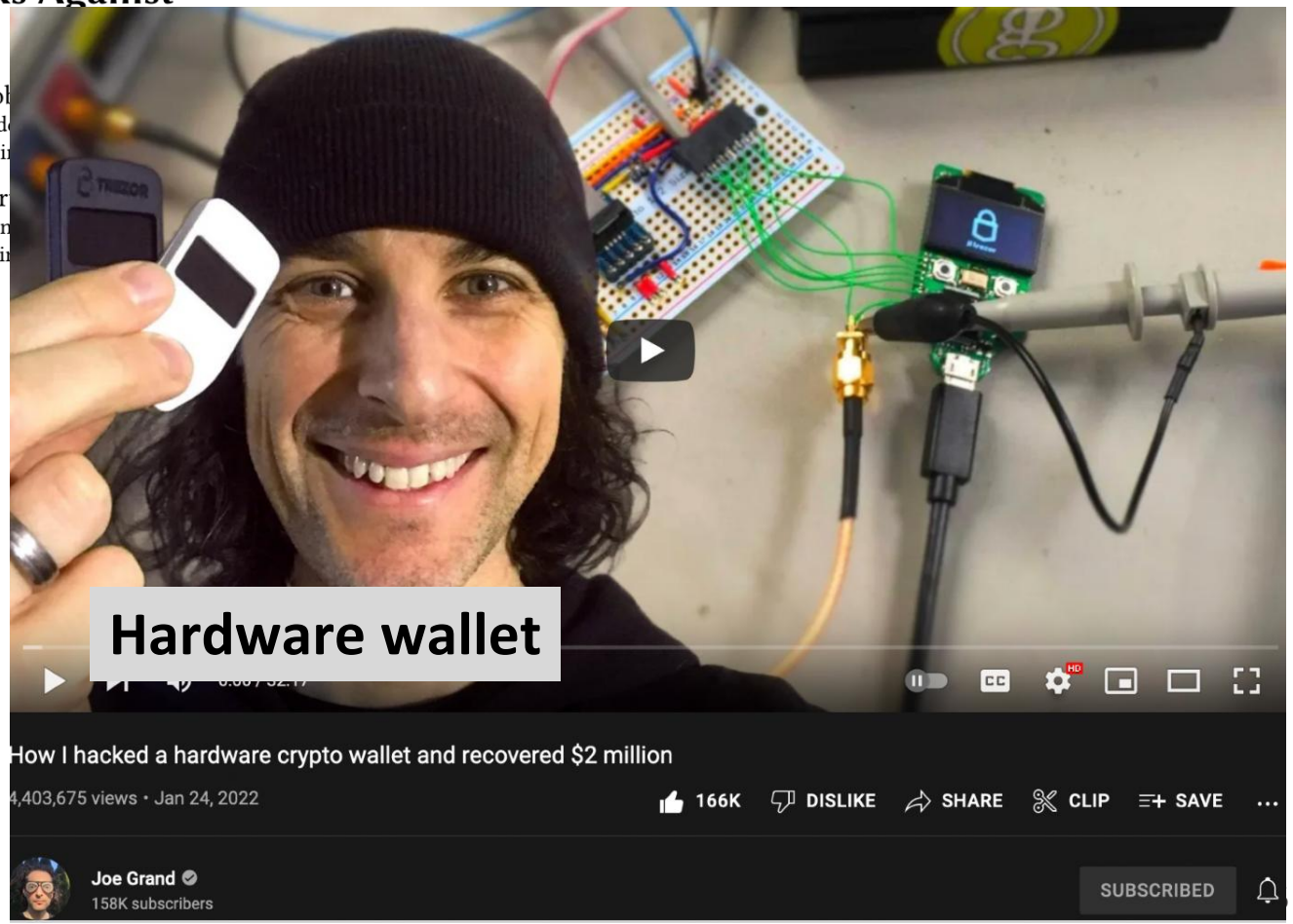
Hans Niklas Jacob
hnj@sect.tu-berlin.de
Technische Universität Berlin

Jean-Pierre Seifert
jpseifert@sect.tu-berlin
Technische Universität Berlin
Fraunhofer SIT

AMD's root of trust

Tesla's infotainment system





Hardware wallet

Physical Attacks Were Used In Many Real-World Attacks

XBOX360

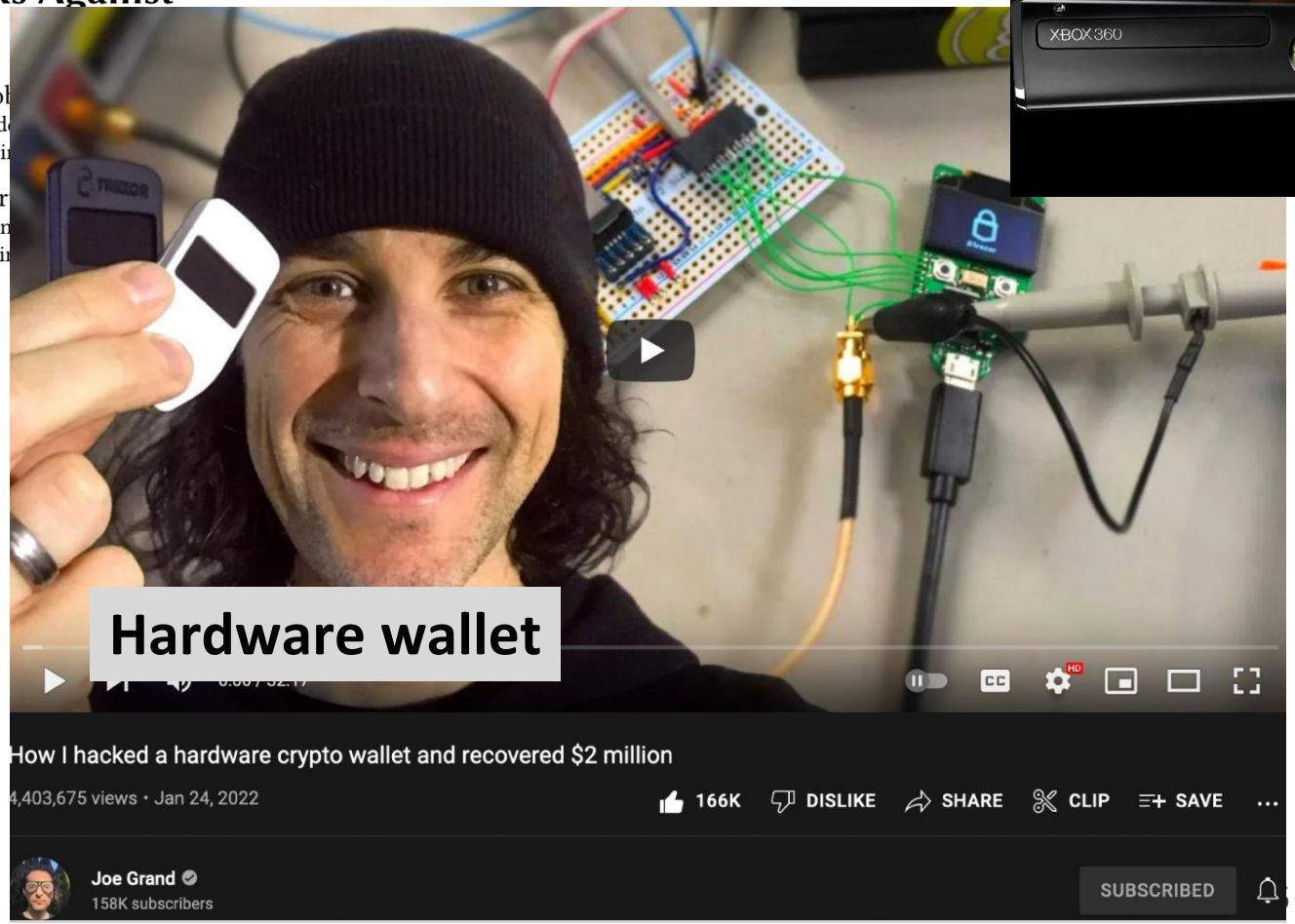
One Glitch to Rule Them All: Fault Injection Attacks Against AMD's Secure Encrypted Virtualization

Robert Buhren
robert.buhren@sect.tu-berlin.de
Technische Universität Berlin - SECT

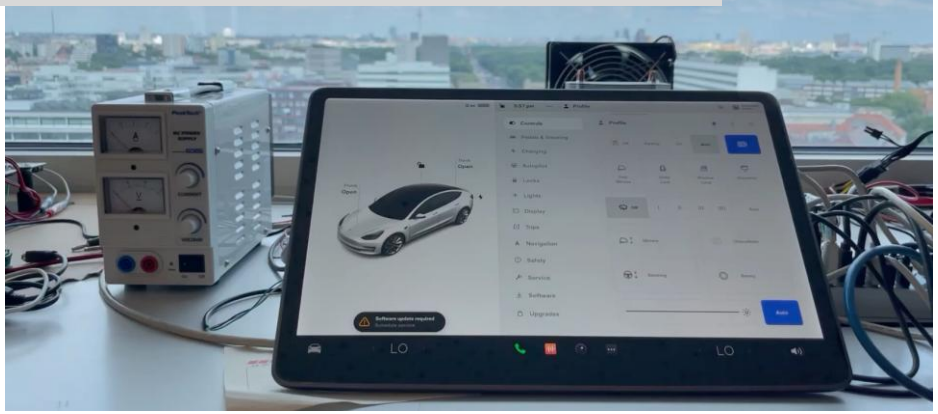
Hans Niklas Jacob
hnj@sect.tu-berlin.de
Technische Universität Berlin

Jean-Pierre Seifert
jpseifert@sect.tu-berlin
Technische Universität Berlin
Fraunhofer SIT

AMD's root of trust



Tesla's infotainment system



Warm up: Which one is better implementation?

```
if PIN == STORED_PIN:
    unlock()
else:
    failed_attempts++;
```

```
pin_attempts++;
if PIN == STORED_PIN:
    unlock()
```

Say you are implementing a pin-protected hardware wallet. Which one is the better implementation?

Warm up: Which one is better implementation?

```
if PIN == STORED_PIN:
    unlock()
else:
    failed_attempts++;
```

```
pin_attempts++;
if PIN == STORED_PIN:
    unlock()
```

Warm up: Which one is better implementation?

```
if PIN == STORED_PIN:
    unlock()
else:
    failed_attempts++;
```

If we cut power at the right time, failed attempt counter does not increase.

Threat model allows for arbitrarily sophisticated attacks

- Attacker has physical access to your chip
- Access to X$ of equipment, and Y hours of time
- And wants to retrieve a secret on the chip or execute code

Threat model allows for arbitrarily sophisticated attacks

Absolute security is infeasible, but we can drive up the cost of an attack.

How security pros view themselves

vs.

https://www.youtube.com/watch?v=2MB0QzBTT-Q

Physical attacks can roughly be divided into side-channel and fault-injection attacks

Fault Injection

- Attacker disturbs chip's computation to bypass authorization or recover a secret key

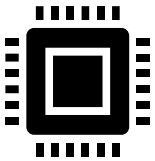
Side Channel

- Inadvertent leakage while the device is performing computation (e.g., through voltage) allows attacker to recover secret information

Physical attacks can roughly be divided into side-channel and fault-injection attacks

Fault Injection	▪ Attacker disturbs chip's computation to bypass authorization or recover a secret key
Side Channel	▪ Inadvertent leakage while the device is performing computation (e.g., through voltage) allows attacker to recover secret information

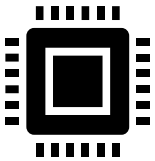
Physical Attacks Exploit Miscomputations In a Victim Device



```
authorized = permissioncheck()
if authorized == true:
   //execute transaction, execute
attacker code..
```

Attackers inject faults during permission check to bypass pin-check, execute custom code,…

Physical Attacks Exploit Miscomputations In a Victim Device



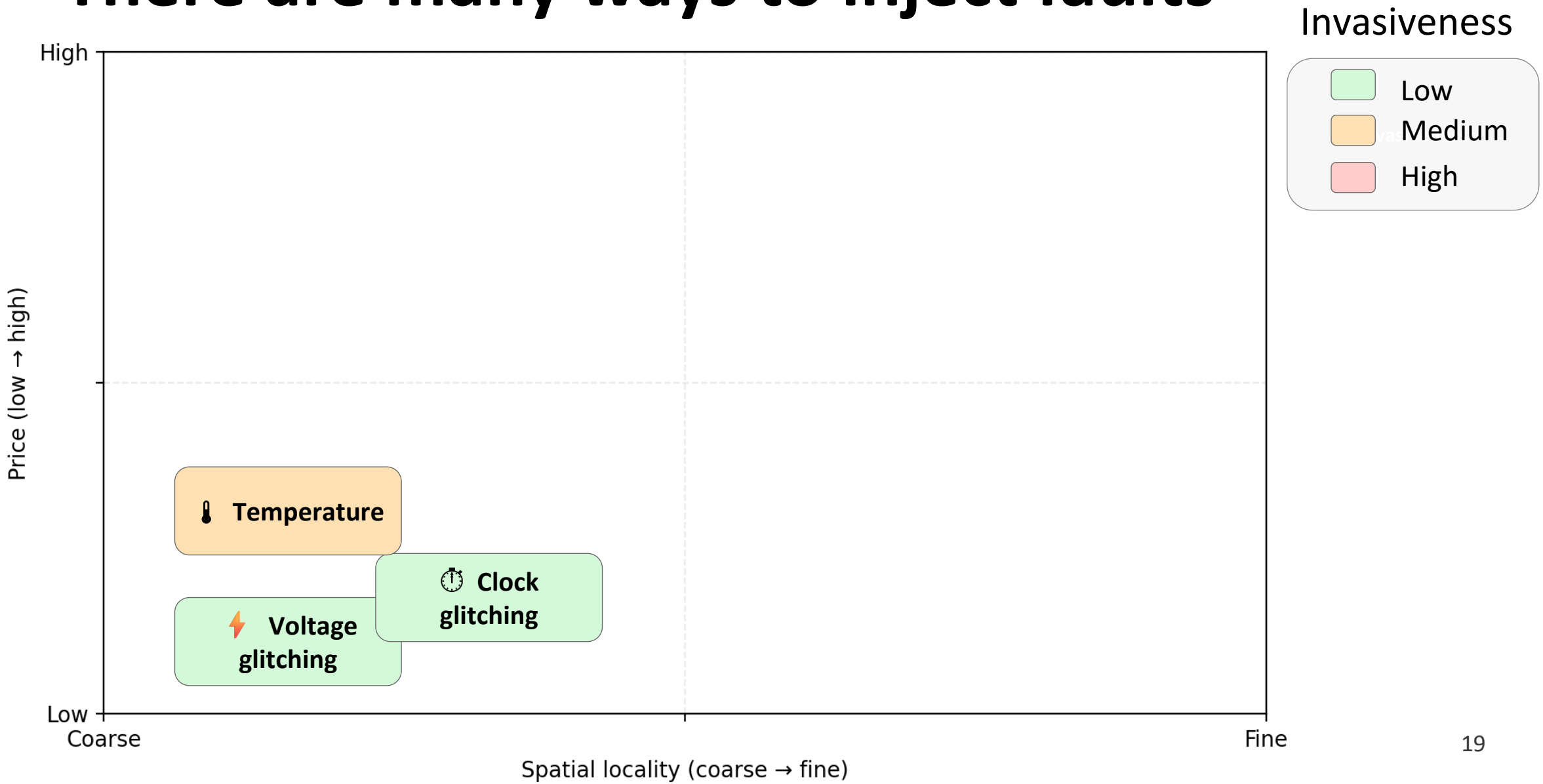
```
authorized = permissioncheck()
if authorized == true:
   //execute transaction, execute
attacker code..
```

Attackers inject faults during permission check to bypass pin-check, execute custom code,…

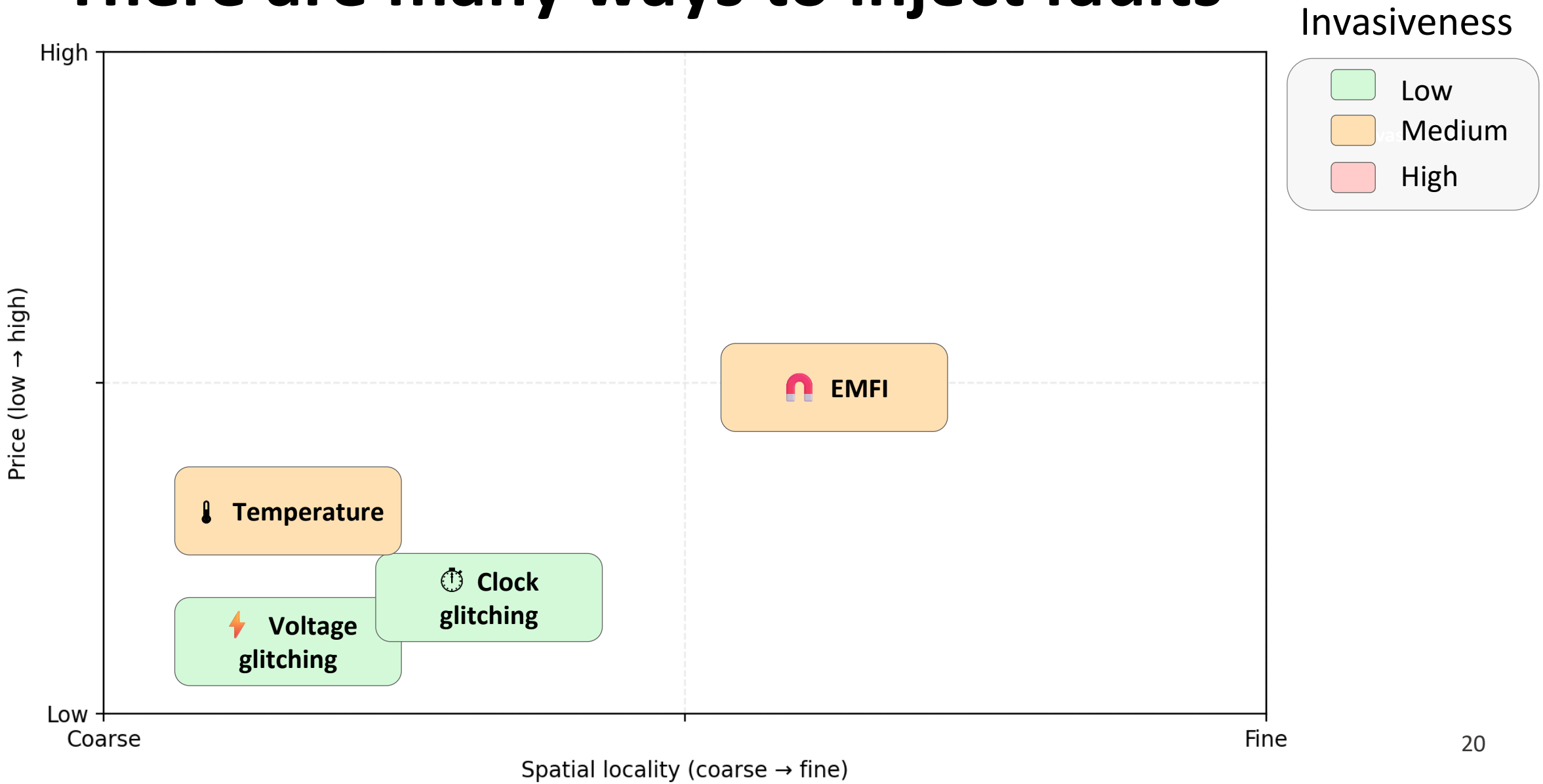
Attackers inject faults during cryptographic computation, and recover the secret key from faulty outputs

- What physical attacks can we use to disturb a chip’s computation?

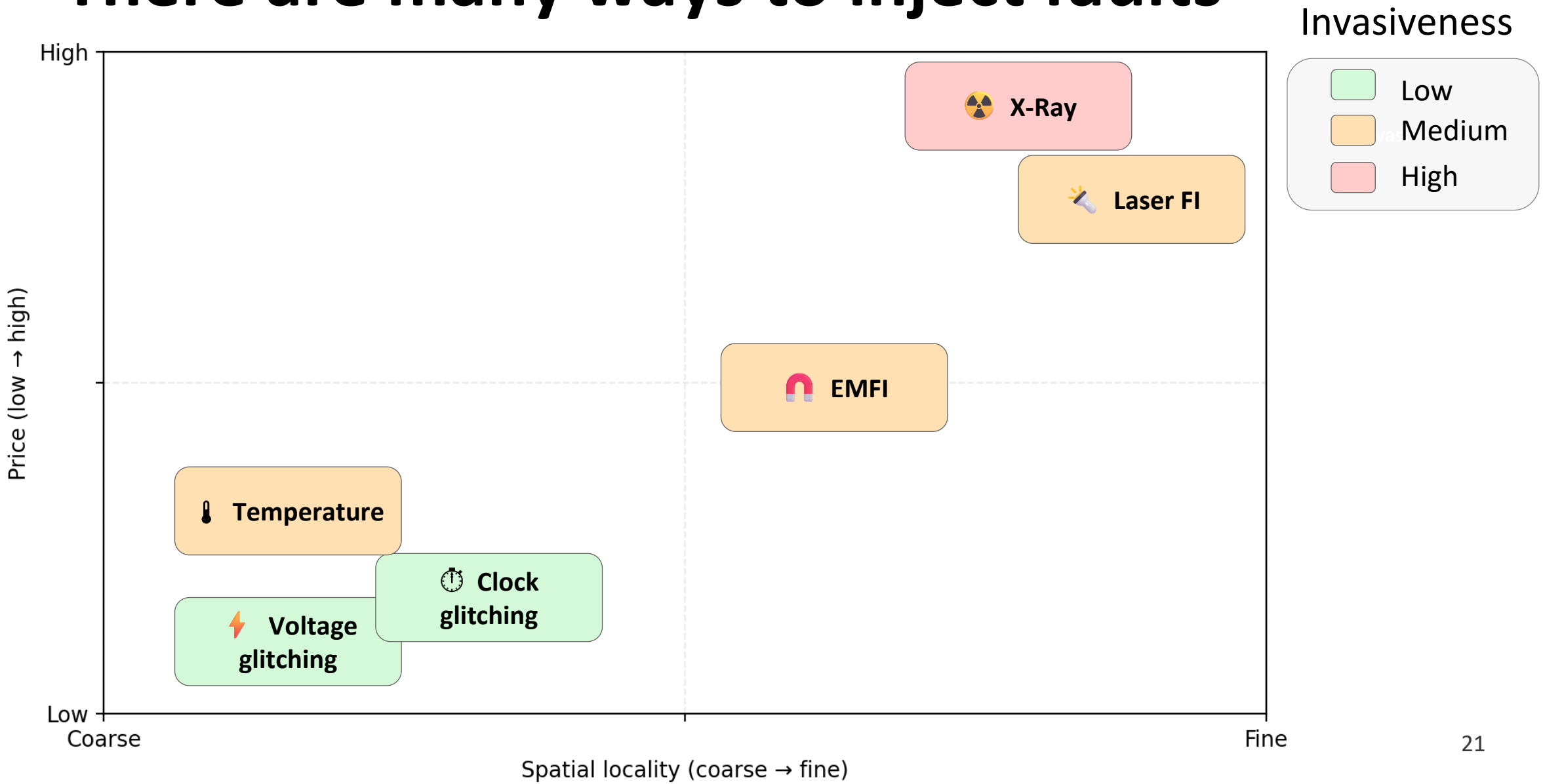
There are many ways to inject faults



There are many ways to inject faults

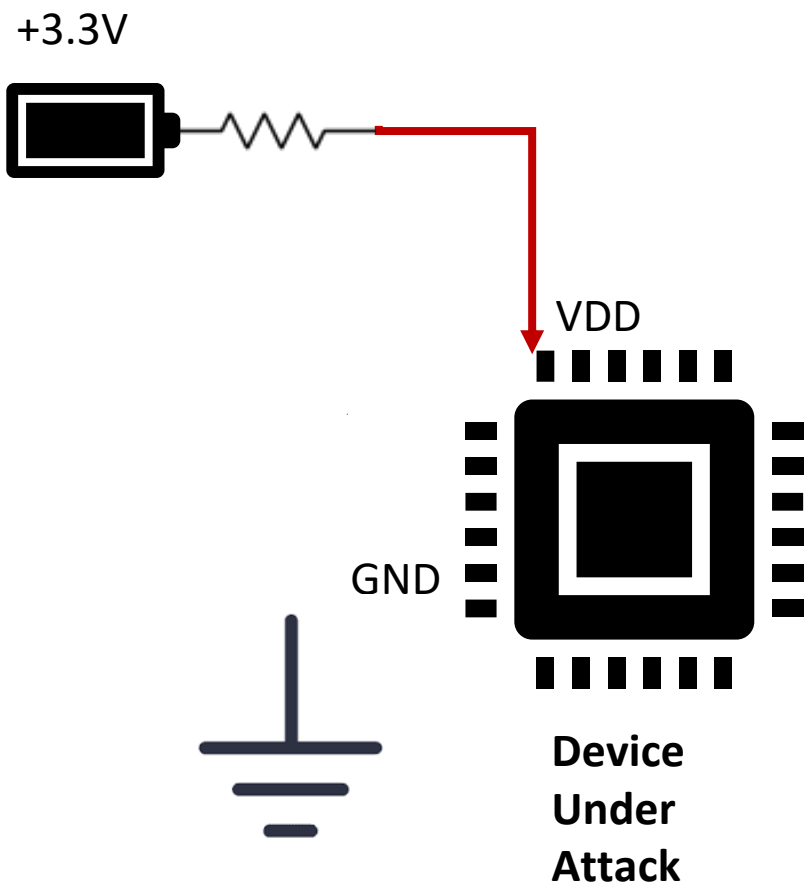


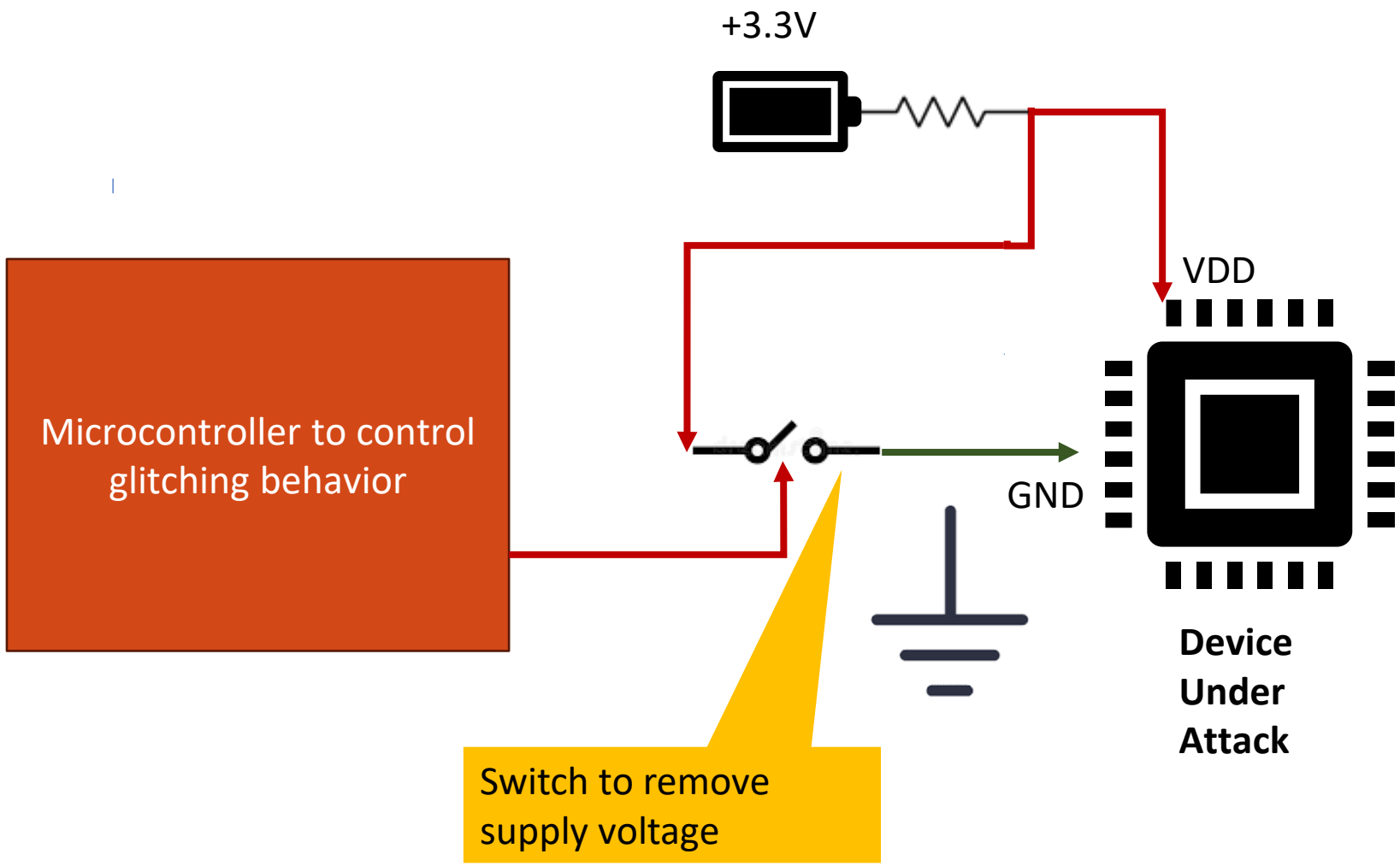
There are many ways to inject faults

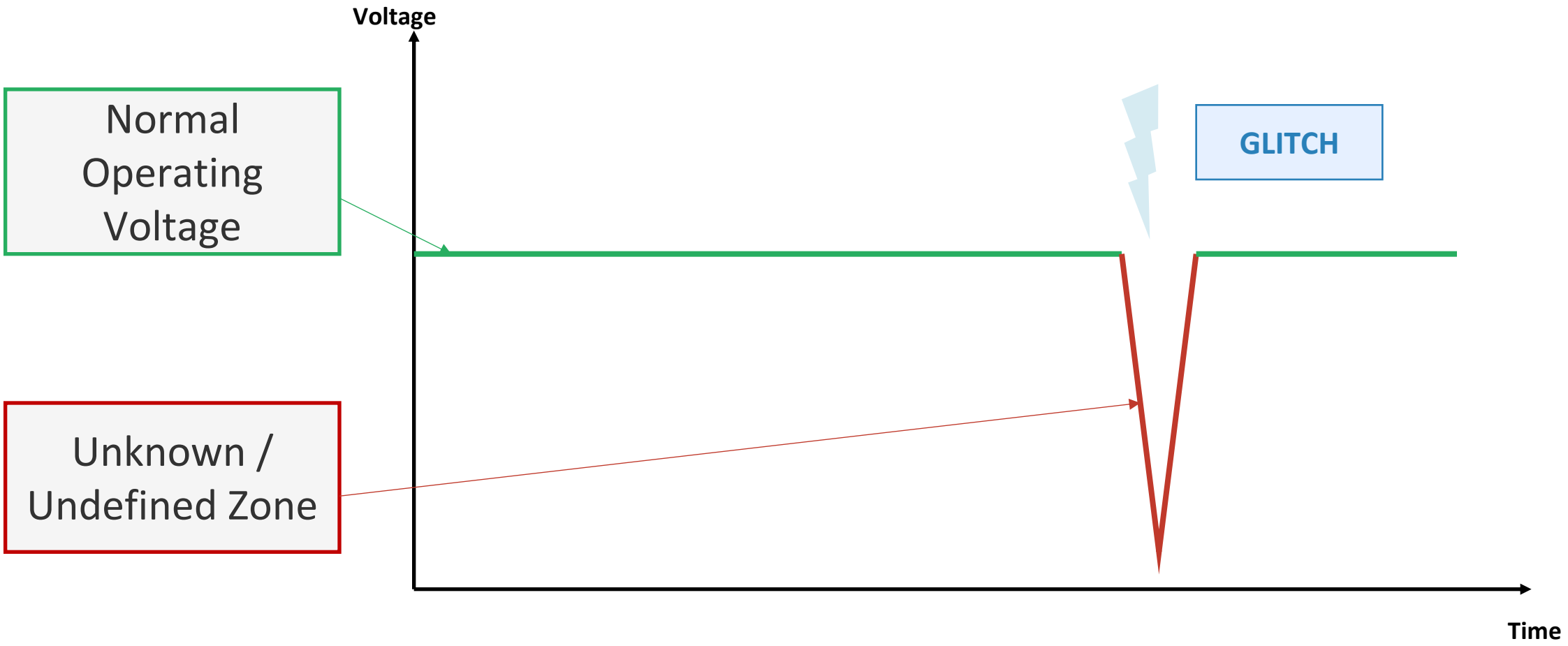


Voltage Glitching

- Manipulating the power supply causes faulty behavior on a device.
- Can be achieved by creating voltage spikes in a power supply or by underpowering the device.

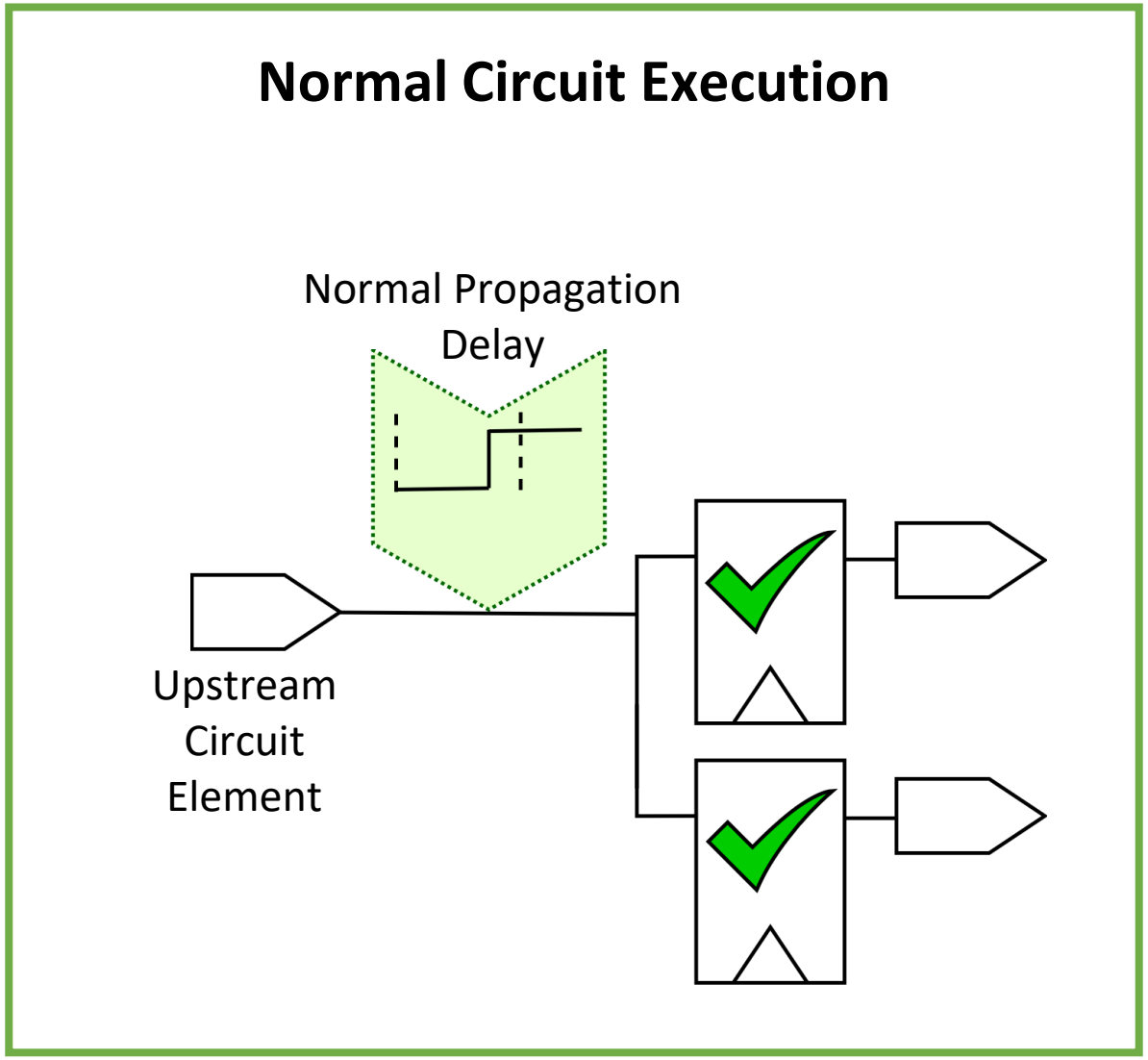

+3.3V
VDD
GND
Device
Under
Attack

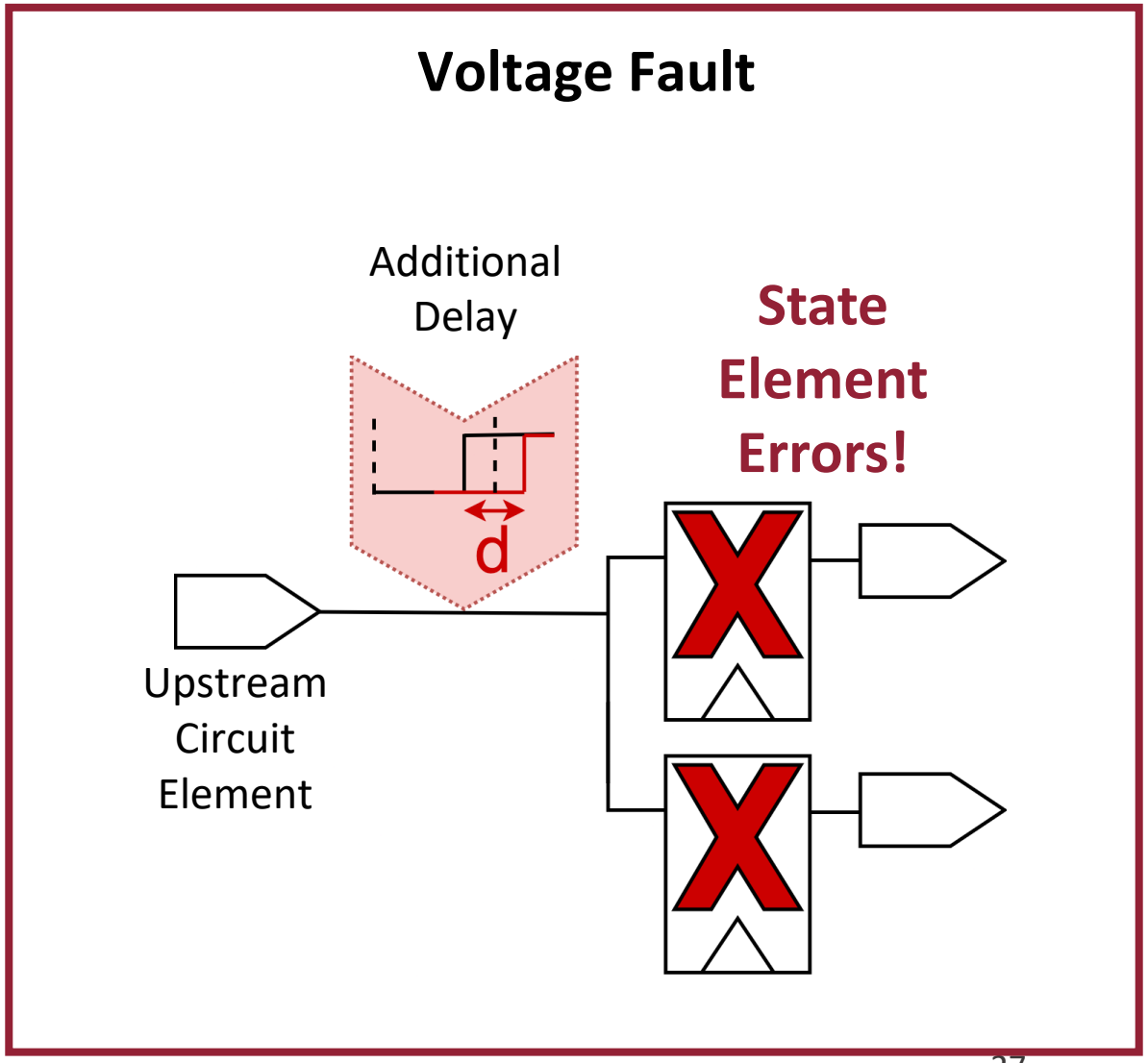

+3.3V
VDD
Microcontroller to control glitching behavior
GND
Device Under Attack
Switch to remove supply voltage


Voltage
Normal Operating Voltage
GLITCH
Unknown / Undefined Zone
Time

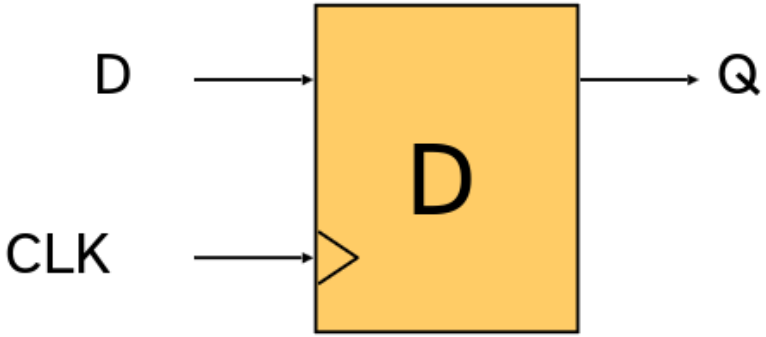
Why does Voltage Glitching result in miscomputations?

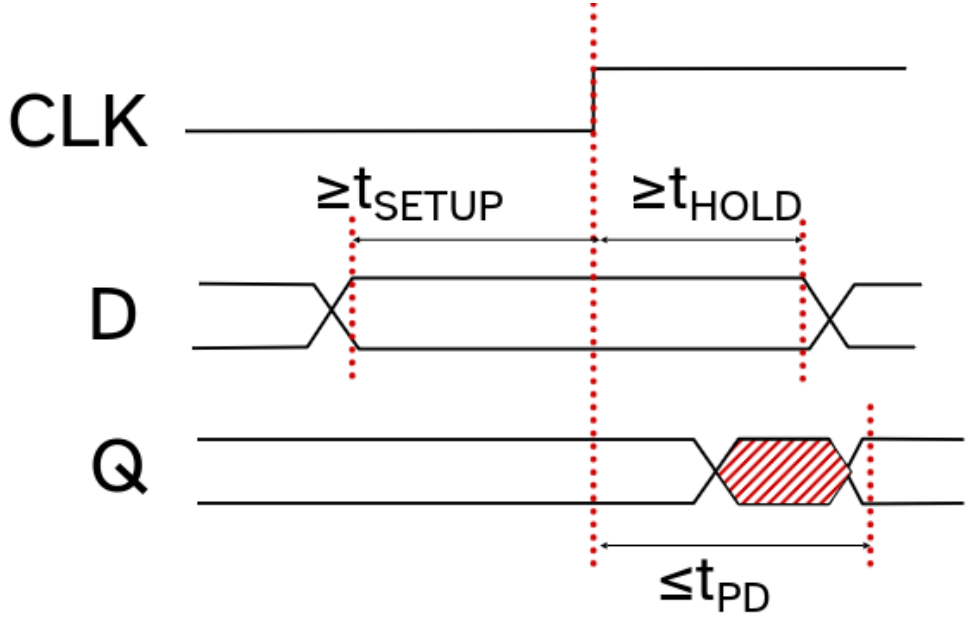
Voltage glitching introduces timing errors





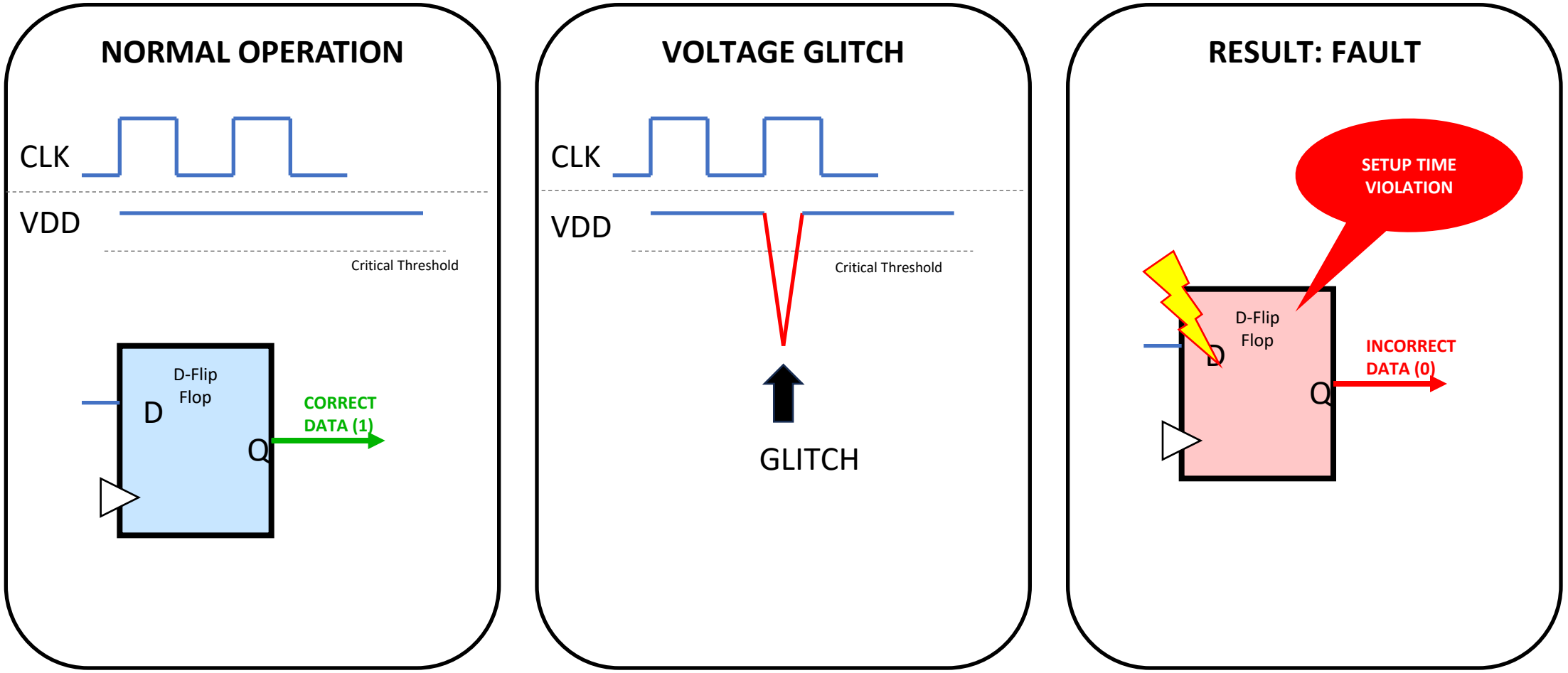
Metastability





- Flip-flop input D should not change around the rising edge of the clock to avoid **metastability**
- Formally, **D should be a stable and valid digital value**:
  - For at **least *tSETUP* before the rising edge of the clock**
  - For at **least *tHOLD* after the rising edge of the clock**
- Violating the timing constraints leaves the circuit in a metastability state. A contaminated value will be loaded into the register.

Voltage glitching reduces switching speed



A voltage dip reduces transistor switching speed. The signal arrives too late for the clock edge.

Timing matters!

```
authorized = permissioncheck()
if authorized == true:
   //execute transaction, execute
attacker code..
```

Injecting at a wrong point: Chip might crash, other control-flow distortions, or simply no effect

Timing matters!

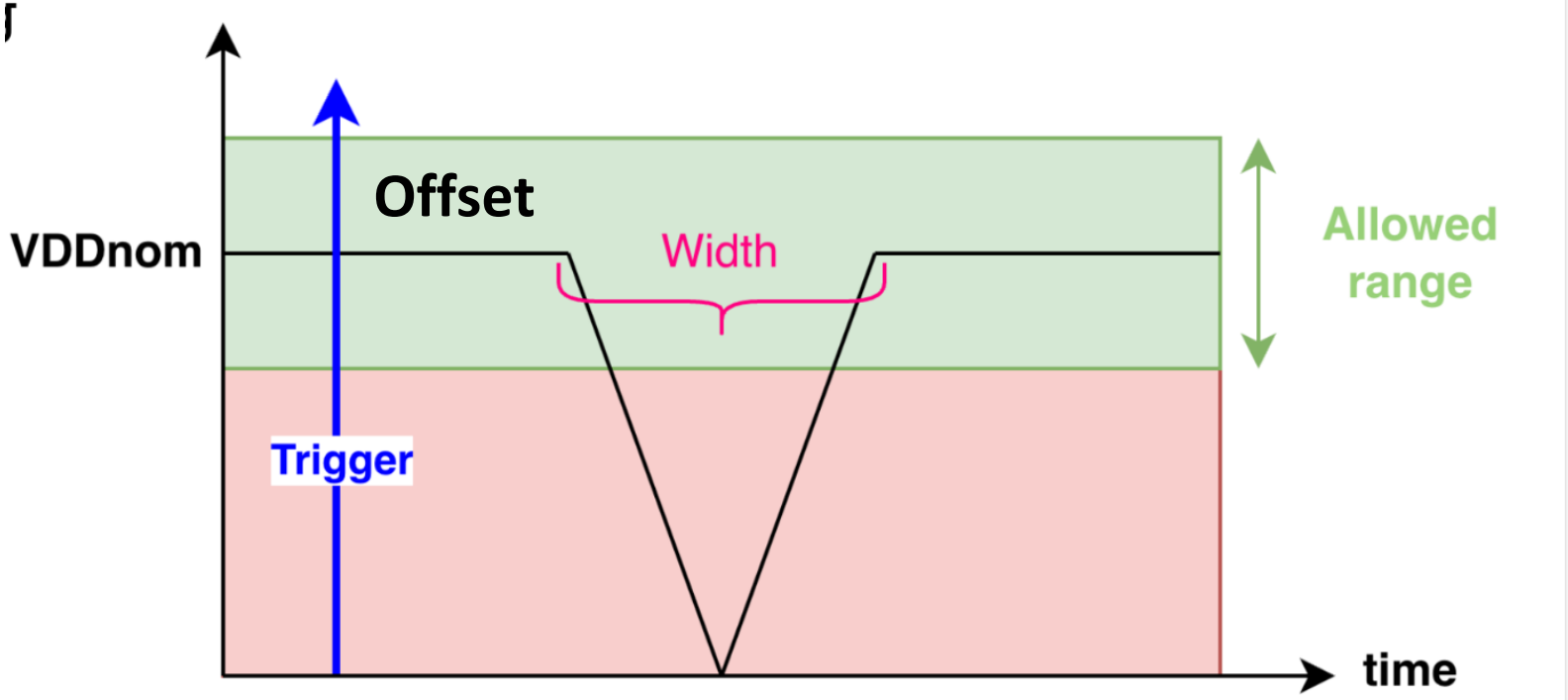
```
authorized = permissioncheck()
if authorized == true:
   //execute transaction, execute
attacker code..
```

In practice: We perform a grid-search over potential fault injection parameters, restarting the process upon a failed glitch.

Voltage glitching can be parameterized by a series of parameters

Important parameters for voltage glitching

- **Offset** (When after the trigger it should occur)
- **width** of the glitch
- **number** of glitches

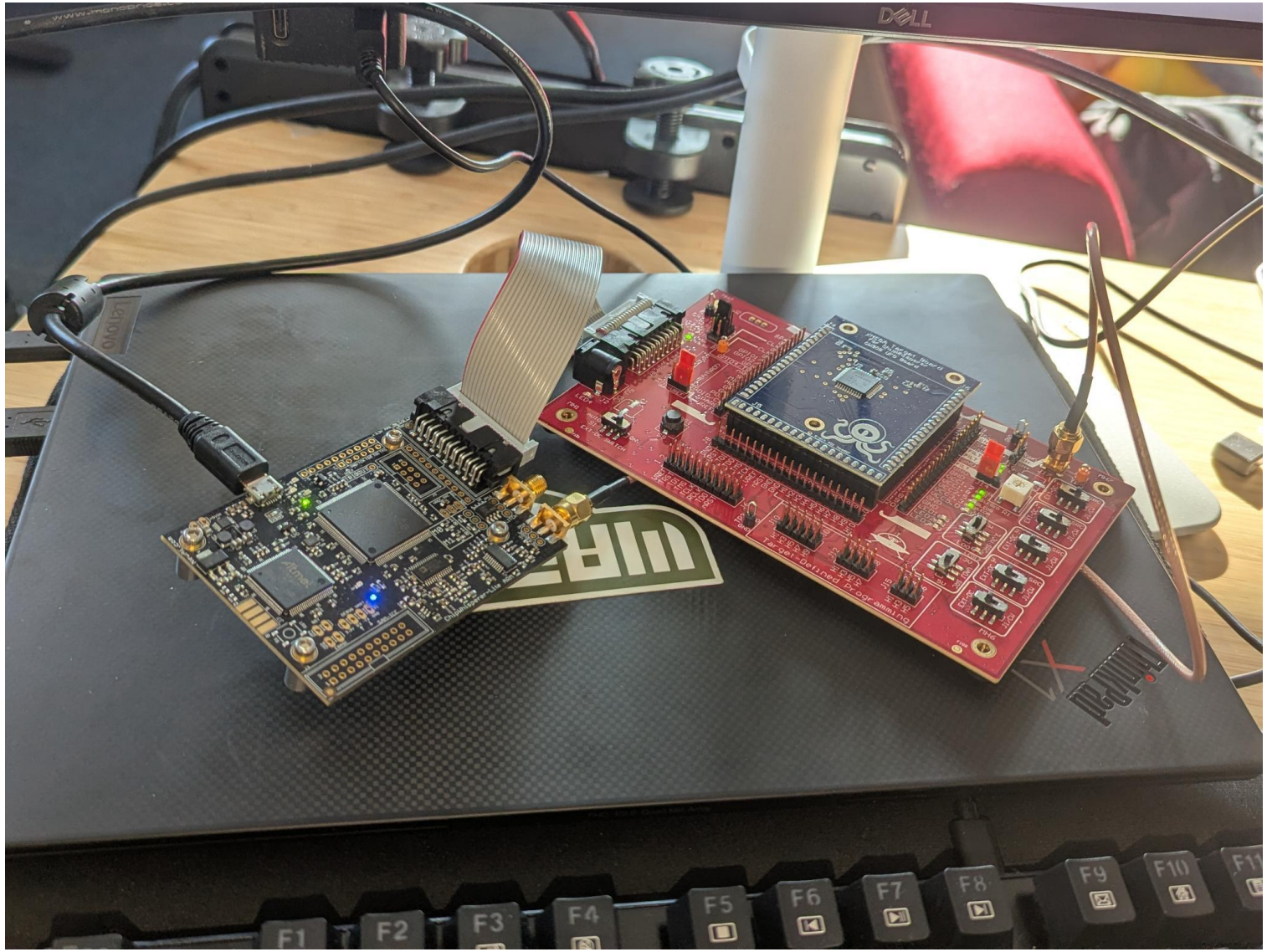


In practice: We perform a grid-search over potential fault injection parameters, restarting the process upon a failed glitch.

Fault-Injection In Practice:

```
for param in gridSearch:
        for i in numTries:
                res = attemptGlitch()
                if res == success: Done!
```

Demo

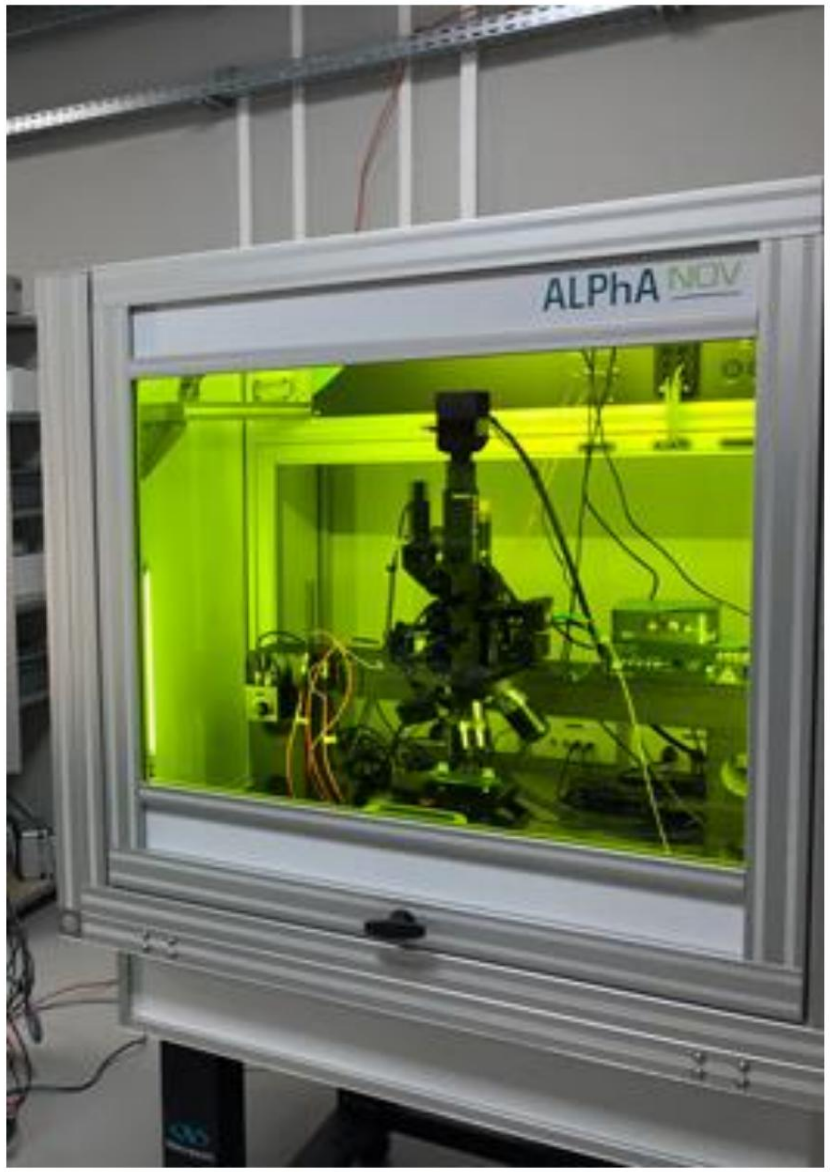


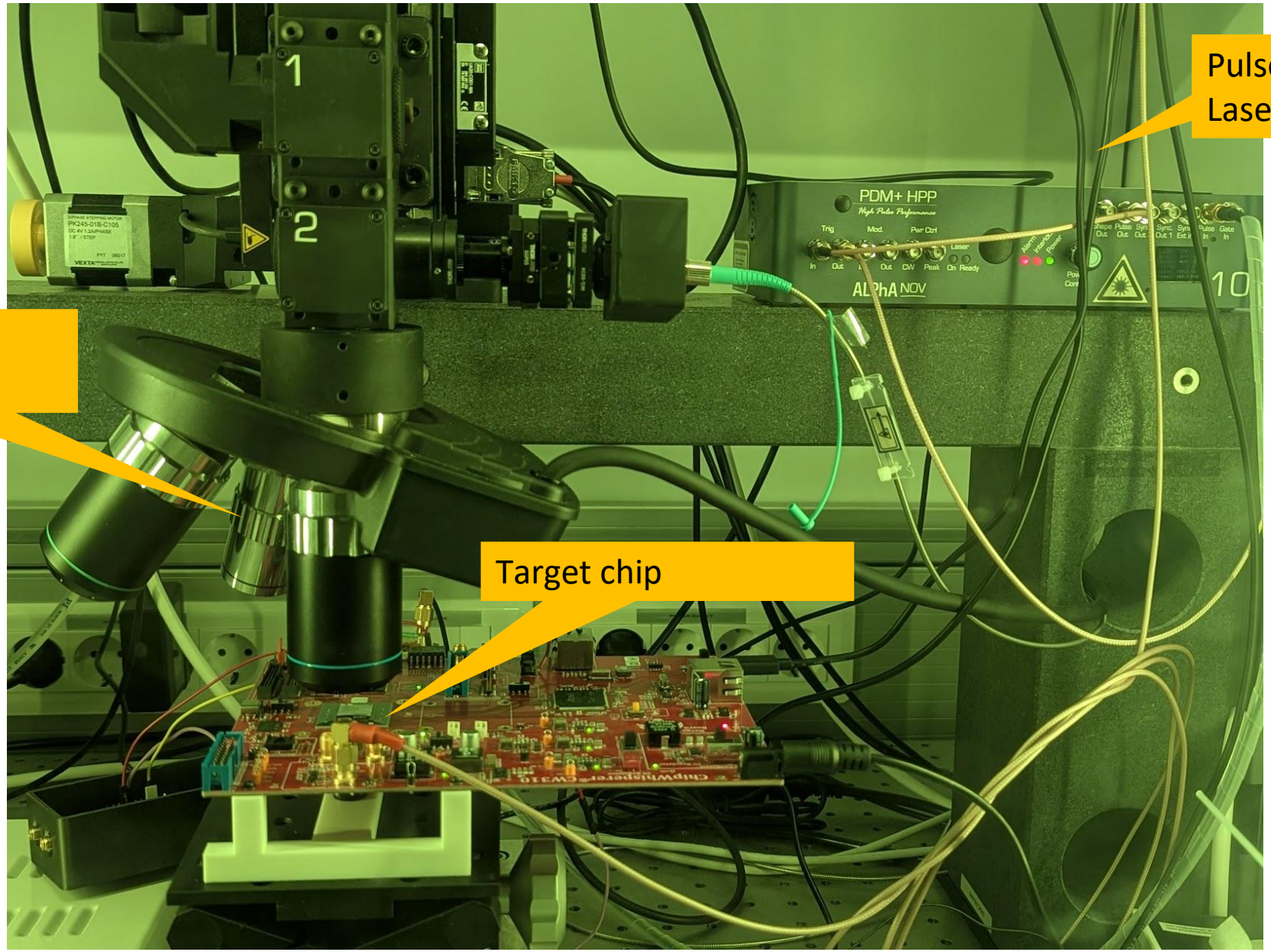
https://wiki.newae.com/Main_Page

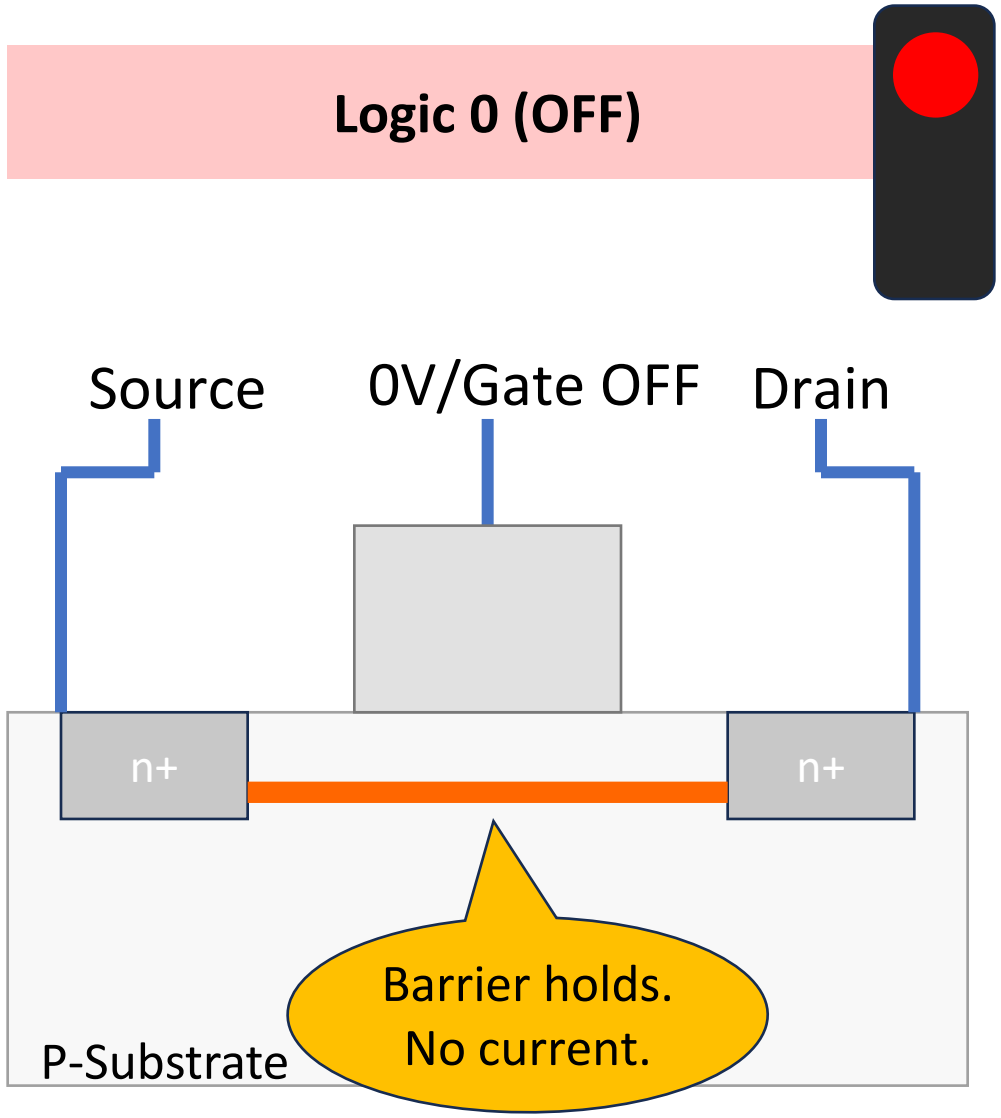
Voltage glitching provides *temporal* (when to inject) control. What if we need to control *spatial* (where to inject) control?

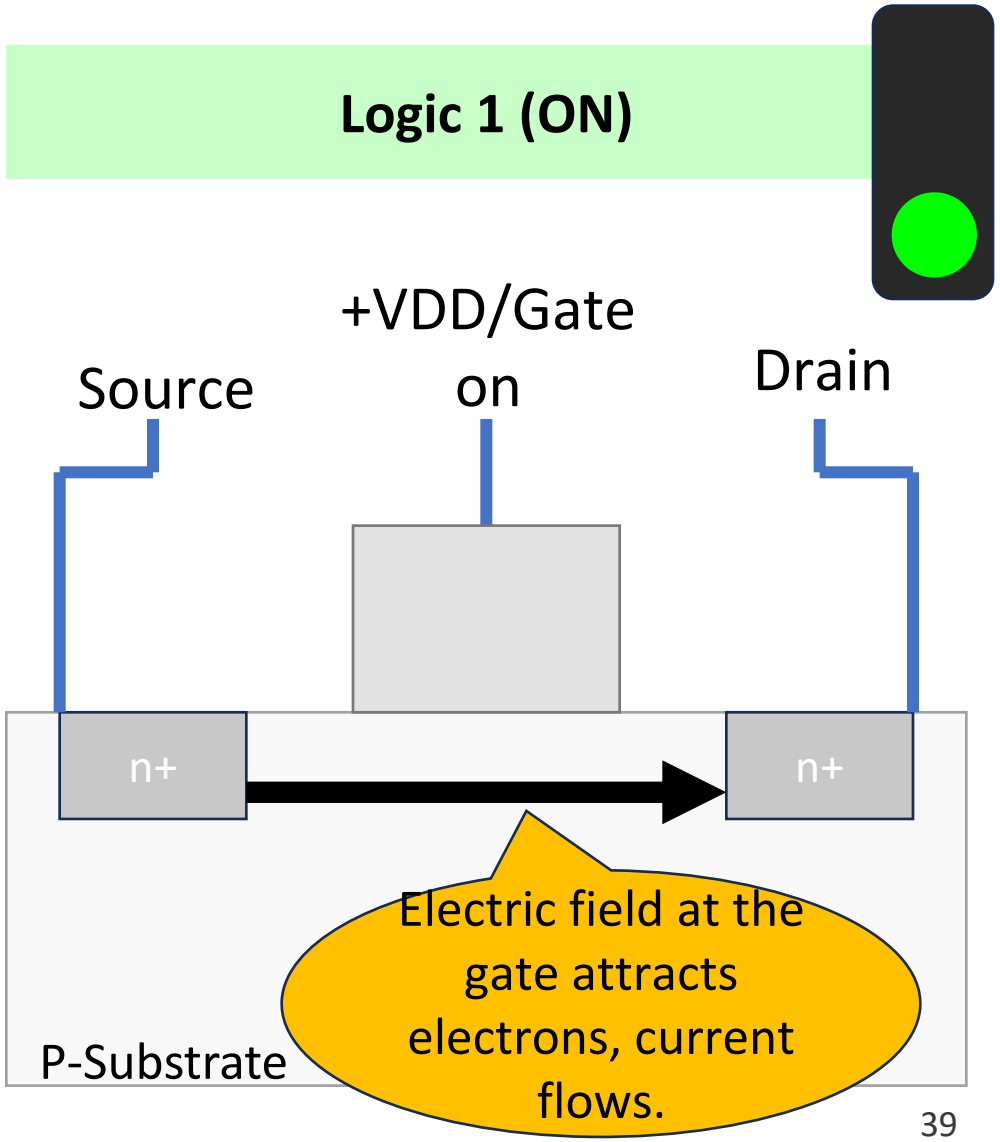
Laser Fault Injection Allows For Temporal And Spatial Control

Laser Fault Injection (LFI): Inject fault by shining a laser onto a chip

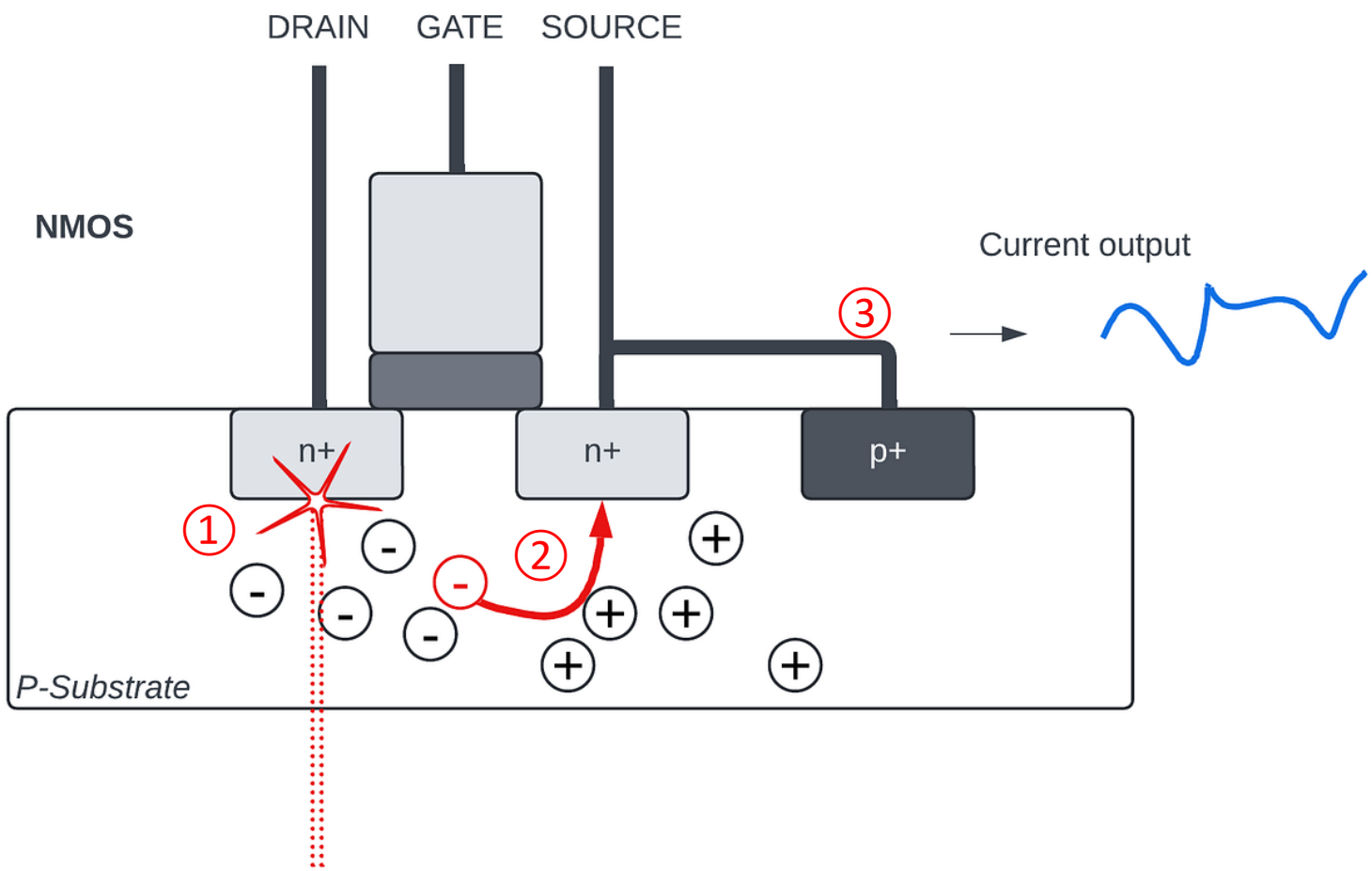



Pulse On Demand
Laser Generator
Microscope to find
right position
Target chip
PDM+ HPP
ALPhA NOV


Logic 0 (OFF)
Source
0V/Gate OFF
Drain
n+
n+
Barrier holds.
No current.
P-Substrate


Logic 1 (ON)
+VDD/Gate
on
Source
Drain
n+
n+
Electric field at the
gate attracts
electrons, current
flows.
P-Substrate

Flipping Bits via Photoexcitation



① High energy photons strike the silicon substrate

② Electron-Hole pairs are created, leading to free carriers

③ A spike in current leads to incorrect downstream values, e.g., flipping a 0 to a 1

https://blog.fraktal.fi/laser-fault-injection-for-the-masses-part-2-b86a42fd28a1

Laser fault injection gives fine-grained spatial and temporal control (single bit-flips in a single cycle!).

Laser fault injection gives fine-grained spatial and fine-grained control (single bit-flips in a single cycle!).

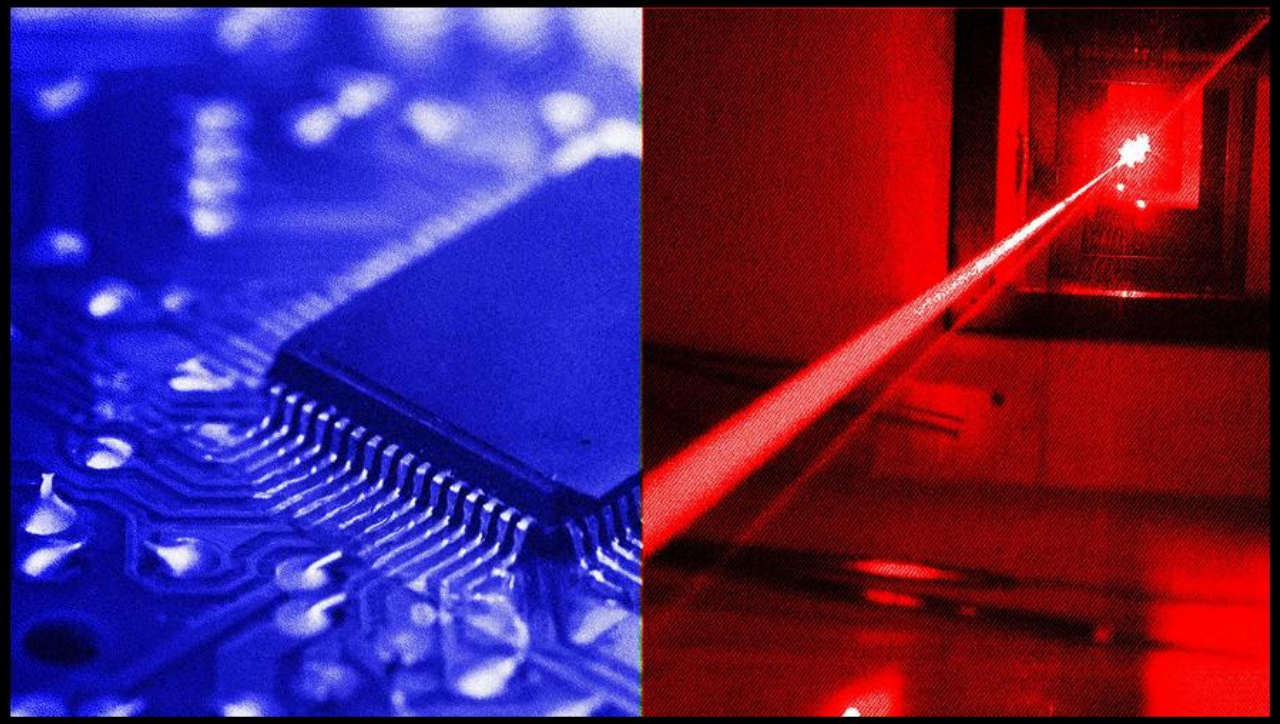
…But cost a 100 thousand dollars and is invasive!

You can 3D-Print your own LFI setup!

ANDY GREENBERG SECURITY AUG 1, 2024 7:00 AM

A $500 Open Source Tool Lets Anyone Hack Computer Chips With Lasers

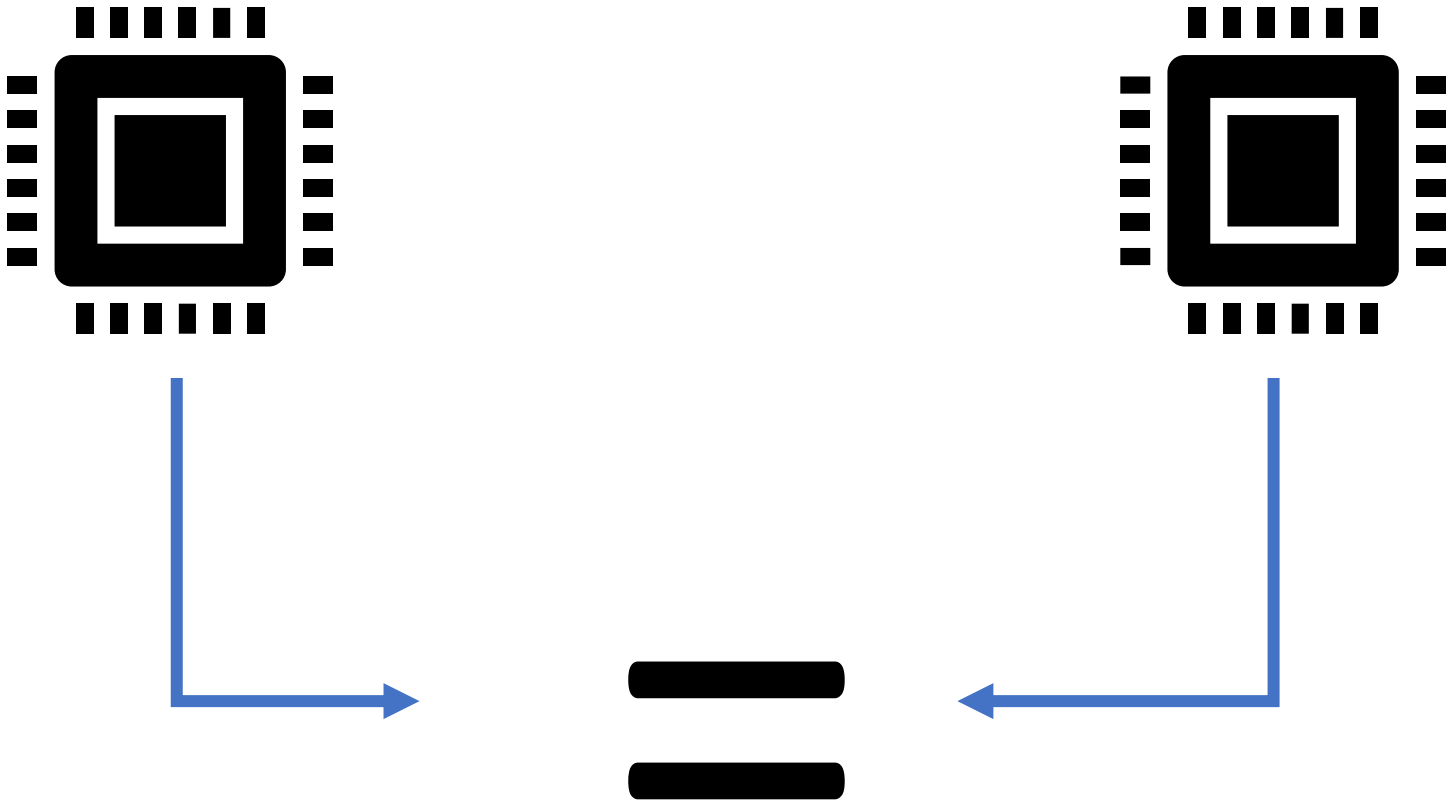
The RayV Lite will make it hundreds of times cheaper for anyone to carry out physics-bending feats of hardware hacking.



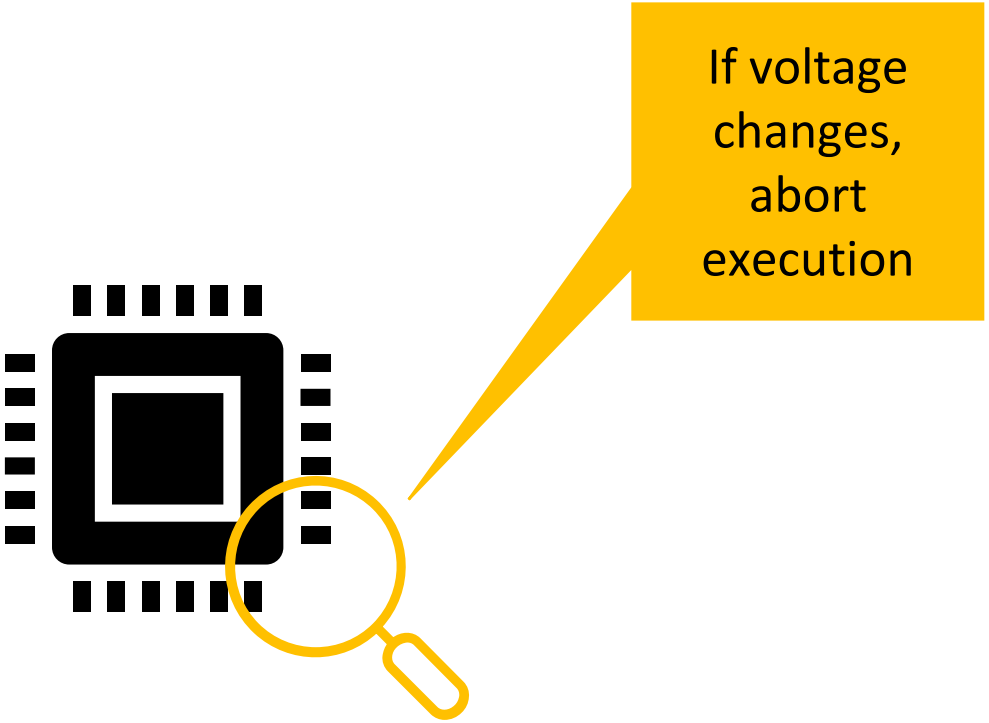
https://github.com/ProjectLOREM/RayVLite

How can we prevent these attacks?

Dual Redundancy



Hardware Sensors



Make the secret on the chip less valuable – breaking *one* chip should not allow control over *all* chips!

Your bike-lock should not cost more than your bike --- which countermeasures to implement is often also “risk acceptance”.

Physical attacks can roughly be divided into side-channel and fault-injection attacks

Fault Injection

- Attacker disturbs chip's computation to bypass authorization or recover a secret key

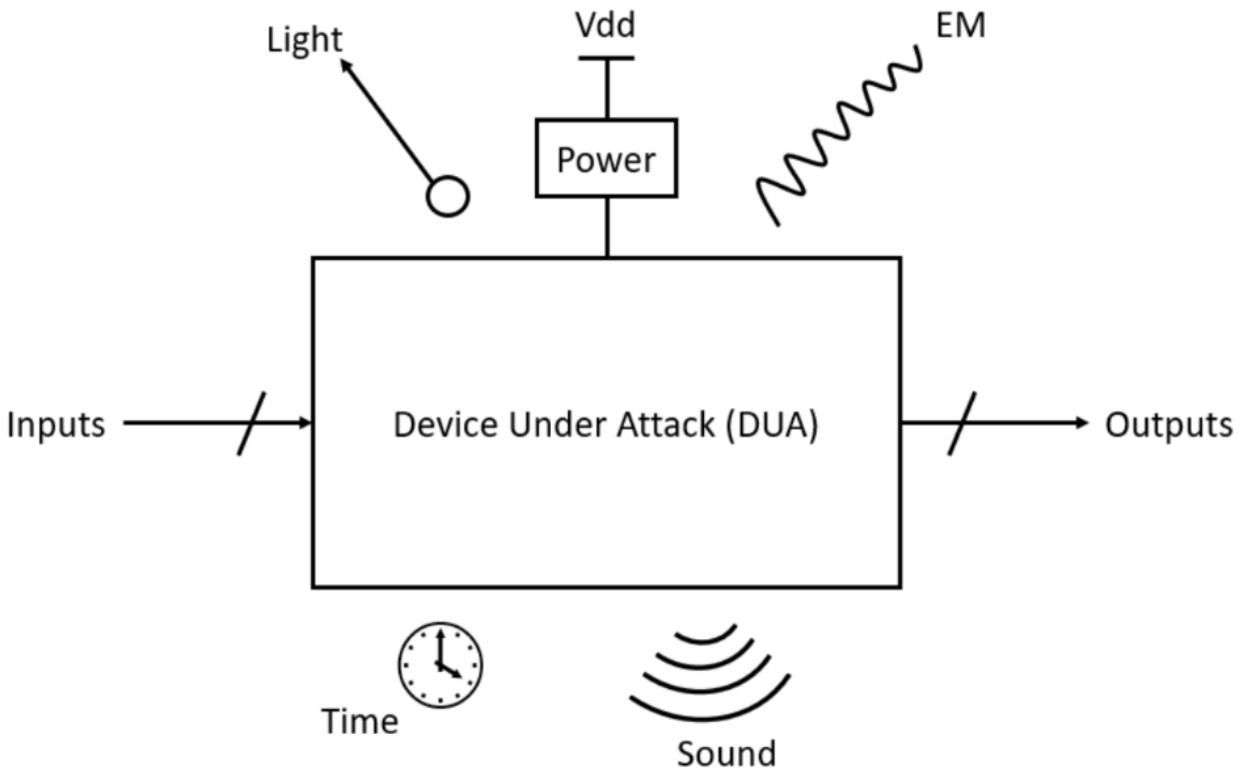
Side Channel

- Inadvertent leakage while the device is performing computation (e.g., through voltage) allows attacker to recover secret information

The power consumption of a device is dependent on the processed data – we can use that to leak a secret!

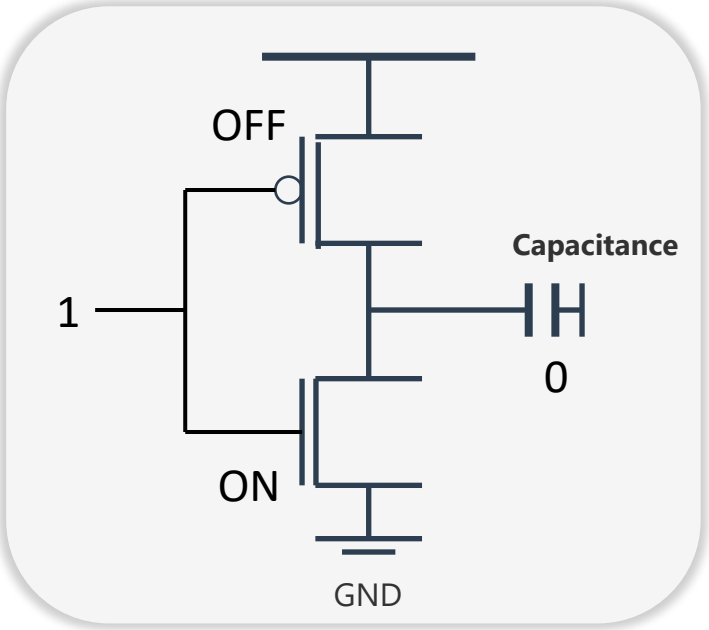
Many channels can be exploited for side-channel leakage

- Typical channels for physical attack: Power, Electromagnetic (EM) emissions.
- Other side-channels: Sound, Temperature, Photonic Emissions..



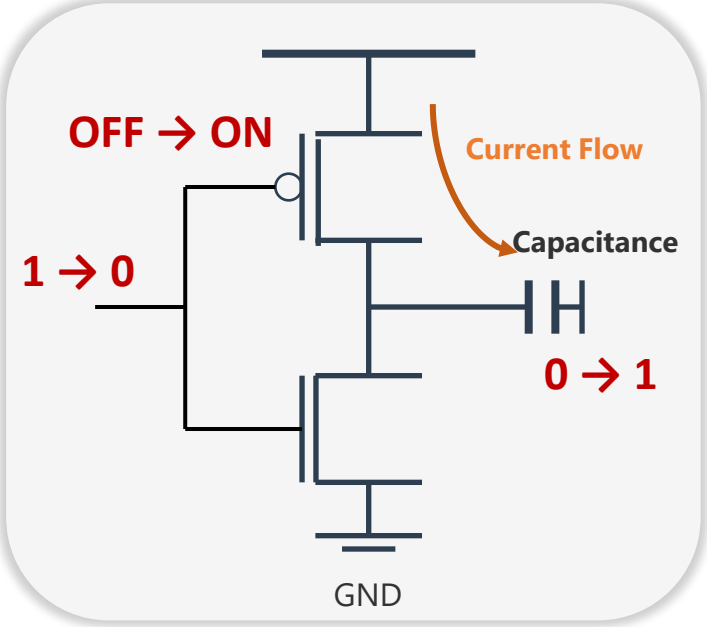
CMOS Technology leaks power when switching

CMOS Inverter

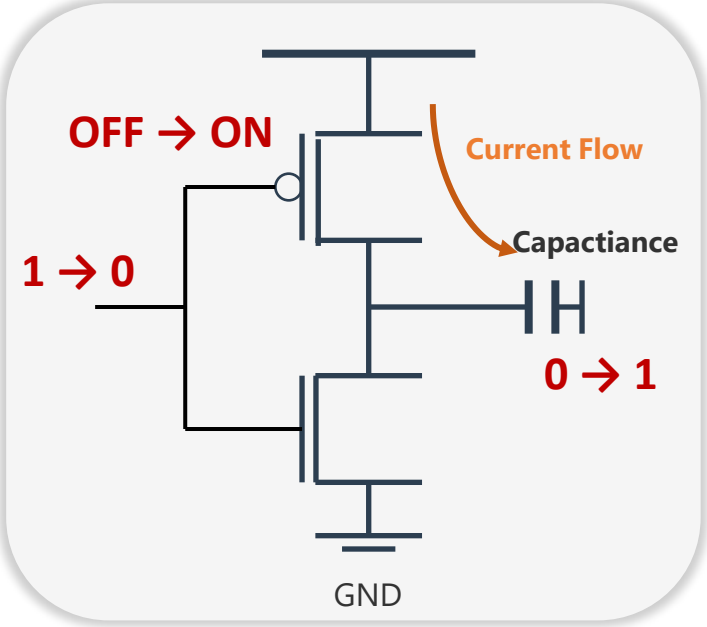


CMOS Technology leaks power when switching

CMOS Inverter



CMOS Technology leaks power when switching



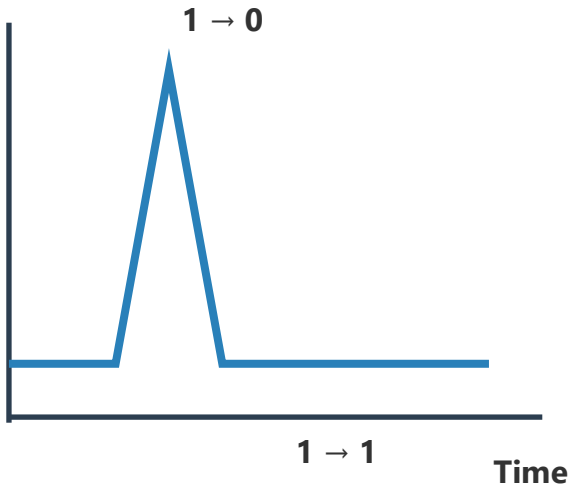
A. Transition (1 → 0)

Power

Current flows from Vdd to the capacitance

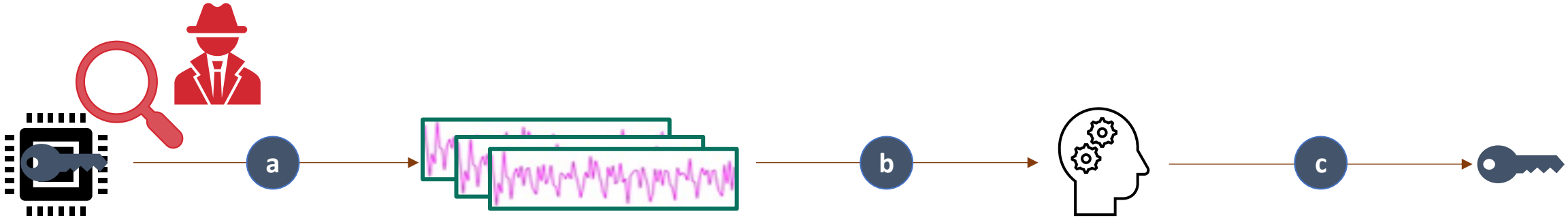
B. Static State (1 → 1)

No change. No Current.



Power consumption is proportional to Switching Activity.

Power Side-Channel attacks exploit leakage through power traces

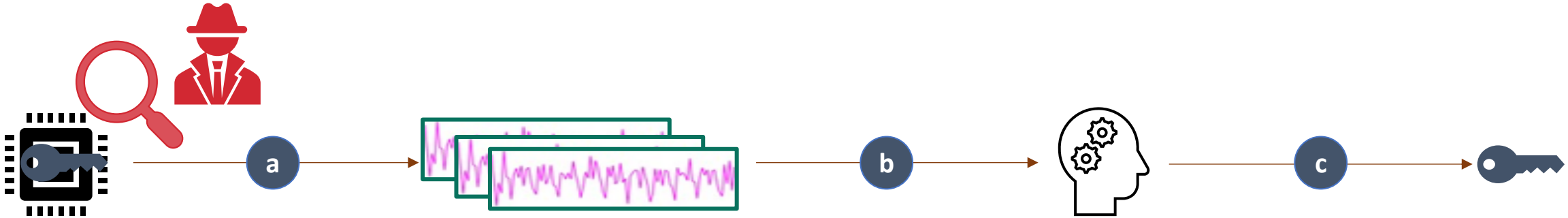


a Attacker measures power traces during signature/encryption computation

b Derives information from *power traces* through statistical analysis

c Recovers secret key from power traces

Power Side-Channel attacks exploit leakage through power traces



a Attacker measures power traces during signature/encryption computation

b Derives information from *power traces* through statistical analysis

c Recovers secret key from power traces

Threat Model:

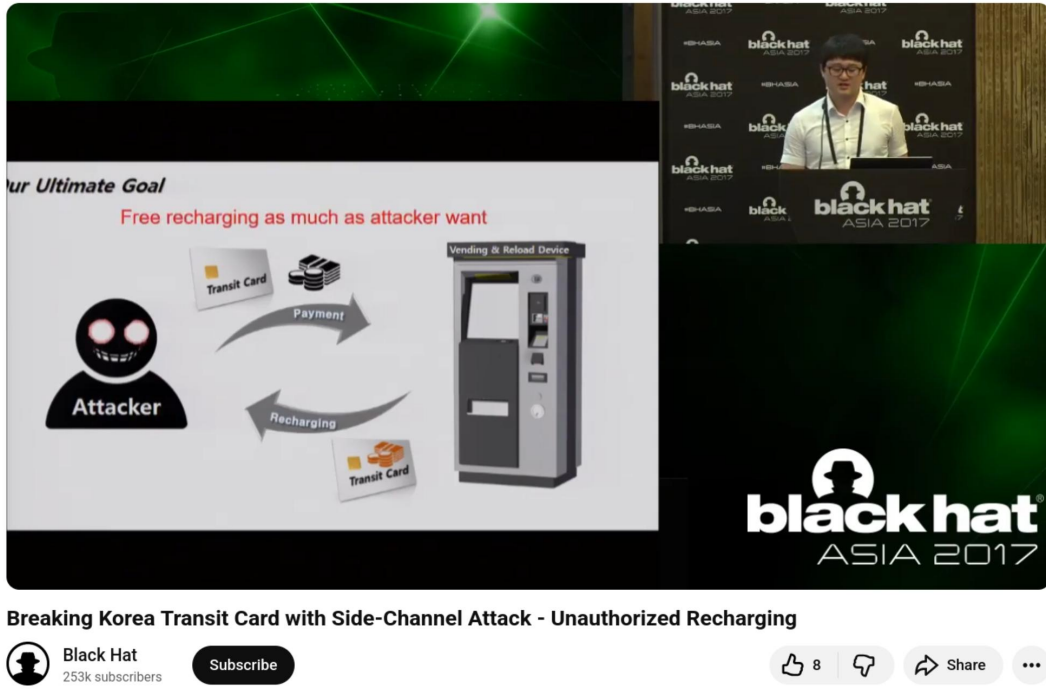
- Attacker has physical access to victim device
- Can measure power during signature/ciphertext computation
- Can observe the signatures created by the device
- Attacker can trigger (multiple) signature/ciphertext generations with potentially custom plaintext

Breaking Korea Transit Card with Side-Channel Attack - Unauthorized Recharging

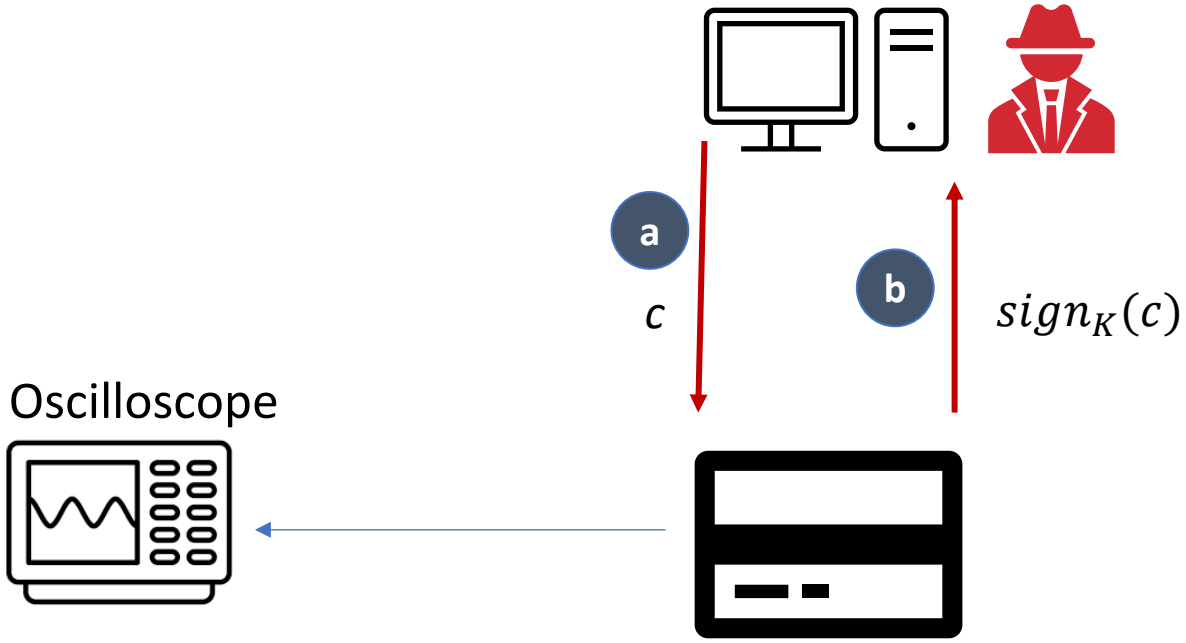
Black Hat
253k subscribers
Subscribe
8
Share

Classical target for power side-channel attacks: Smartcards

- Each transit card shares the *same* secret key with the „recharging station“
- Upon recharging, recharging station and smartcard authenticate each other using this secret key
- This allows to measure power traces and plaintext pairs



Why is this threat model realistic? Smartcard authenticates itself to the reader



a Smartcard reader sends challenge to the card.

b Card replies with signed challenge. The attacker can measure power during signing.

The attacker triggers authentication requests, each creating a power-trace p and message m.

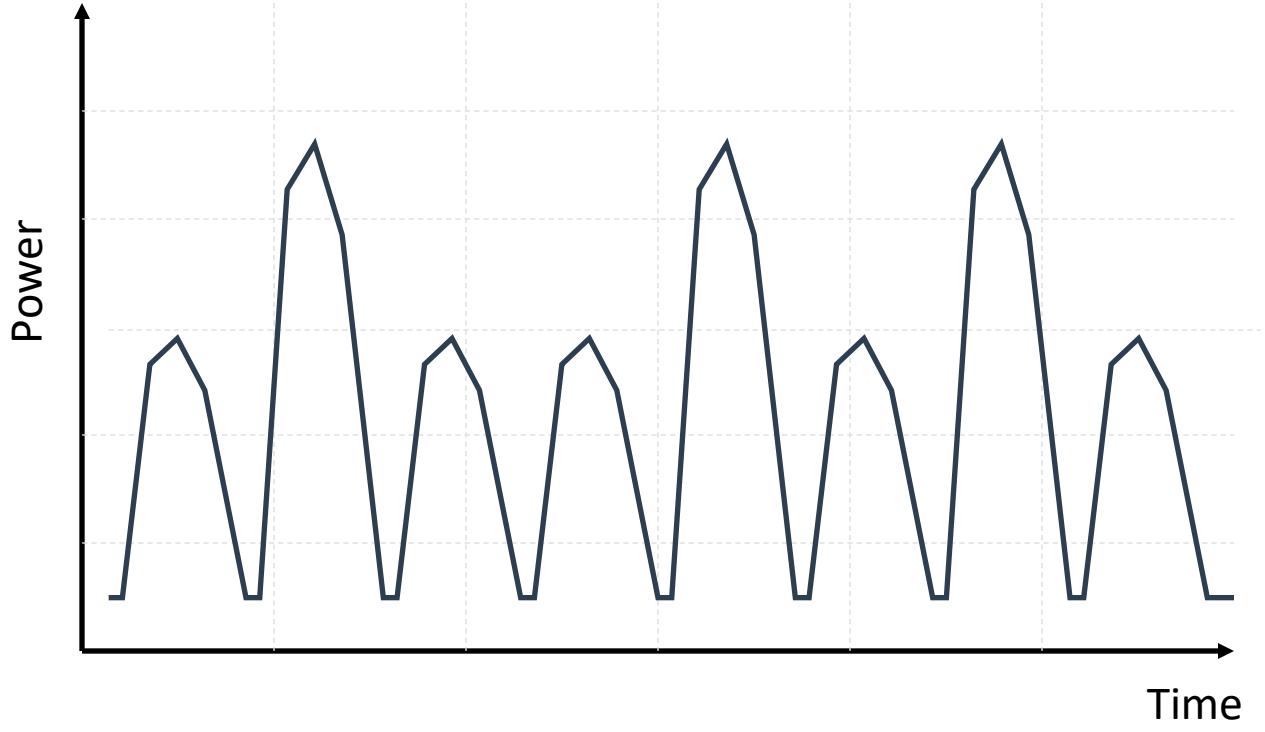
There are multiple ways to recover keys from power leakages

Simple Power Analysis (SPA)	Directly inspect power traces for control-flow patterns.
Differential Power Analysis (DPA)	Divide traces and use statistics to recover key bits.
Correlation Power Analysis (CPA)	Correlate measured power with a leakage model.

There are multiple ways to recover keys from power leakages

Simple Power Analysis (SPA)	Directly inspect power traces for control-flow patterns.
Differential Power Analysis (DPA)	Divide traces and use statistics to recover key bits.
Correlation Power Analysis (CPA)	Correlate measured power with a leakage model.

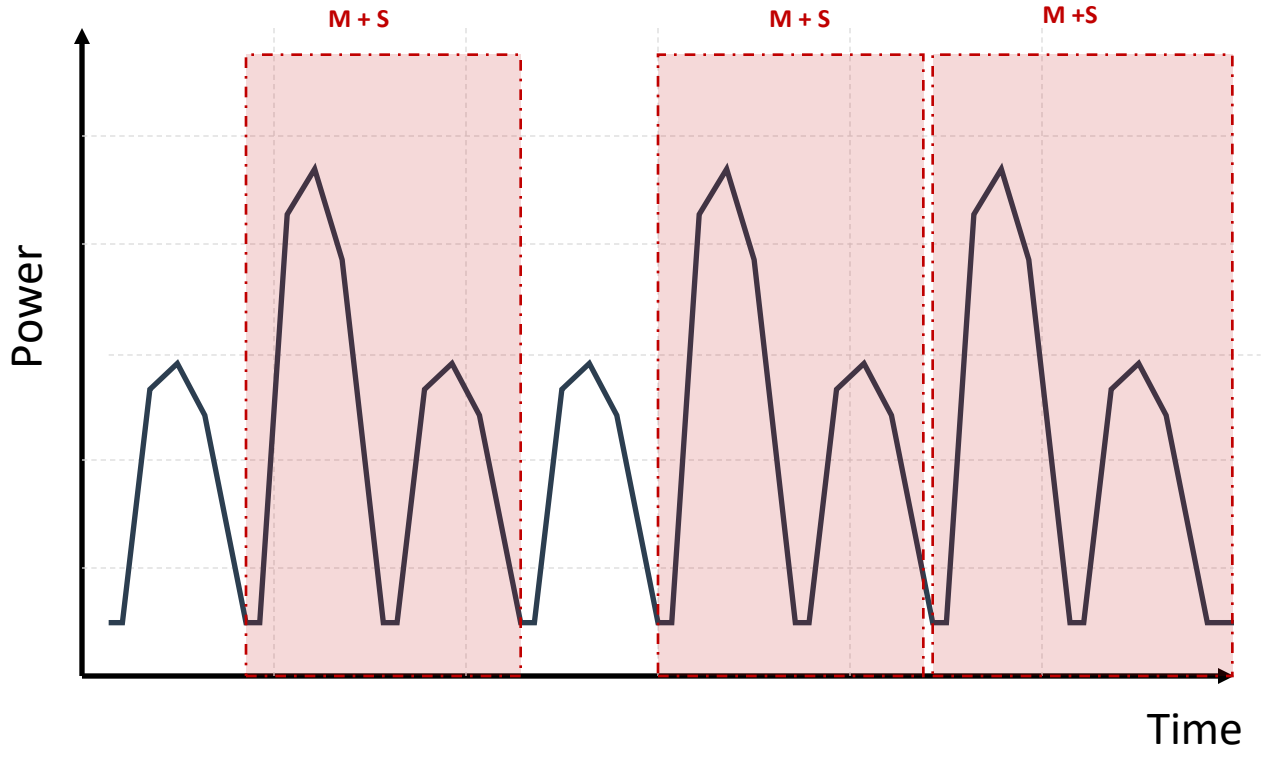
Power-Side Channel Can Distinguish Control-Flow




```
int rsa_modExp(b, e, m) {
  int product = 1;
  while (e > 0) {
    if (e & 1) {
      // BIT IS 1
      product = mult(p, b);
    }
    // ALWAYS DONE
    b = square(b, b);
    e >>= 1;
  }
  return product;
}
```

RSA uses 'Square-and-Multiply'. By observing the power consumption, we can distinguish between Square (0) and Multiply (1) operations.

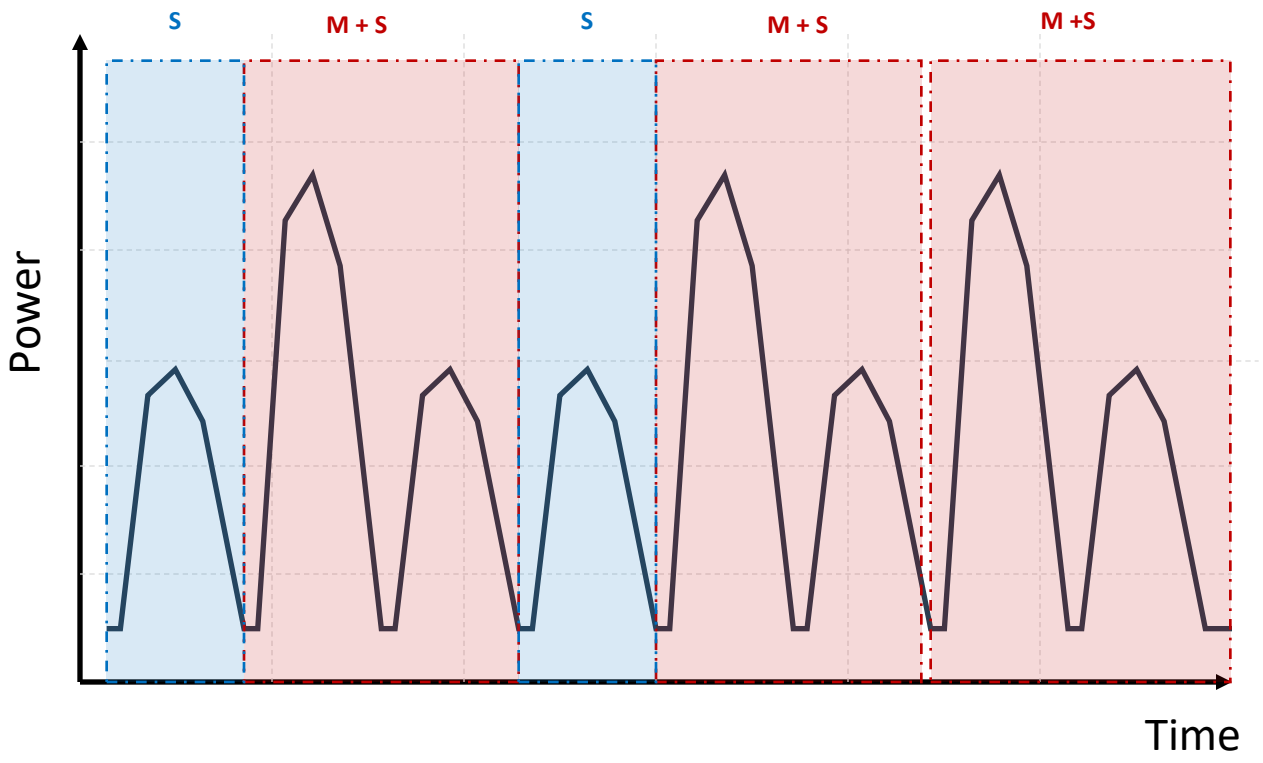
Power-Side Channel Can Distinguish Control-Flow




```
int rsa_modExp(b, e, m) {
  int product = 1;
  while (e > 0) {
    if (e & 1) {
      // BIT IS 1
      product = mult(p, b);
    }
    // ALWAYS DONE
    b = square(b, b);
    e >>= 1;
  }
  return product;
}
```

BIT = 1: The loop executes 'Square' AND 'Multiply'. We see the Square pattern followed immediately by the Multiply pattern.

Power-Side Channel Can Distinguish Control-Flow




```
int rsa_modExp(b, e, m) {
  int product = 1;
  while (e > 0) {
    if (e & 1) {
      // BIT IS 1
      product = mult(p, b);
    }
    // ALWAYS DONE
    b = square(b, b);
    e >>= 1;
  }
  return product;
}
```

BIT = 0: The loop executes ONLY the 'Square' operation. We see a single, distinct pattern in the trace.

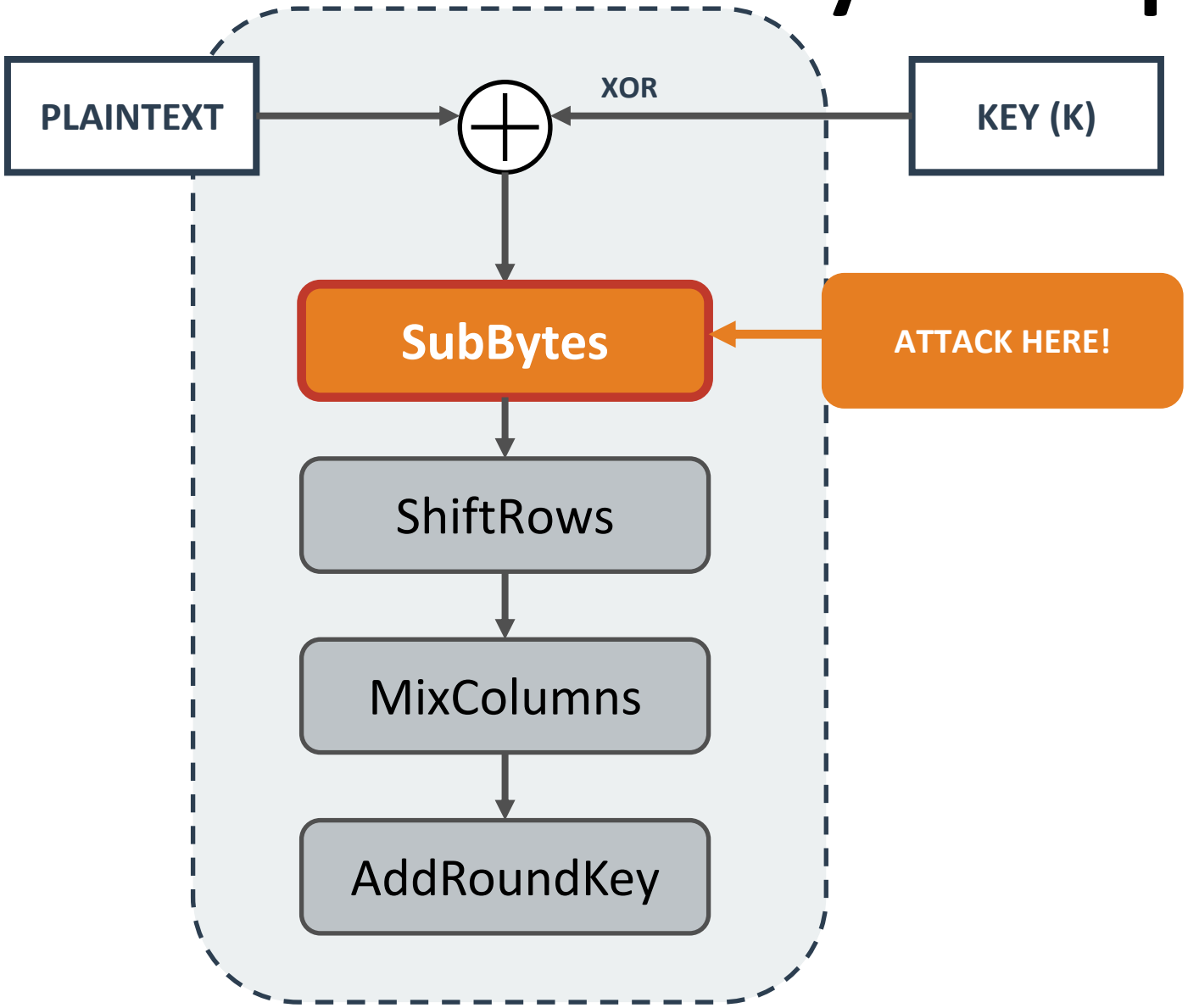
There are multiple ways to recover keys from power leakages

Simple Power Analysis (SPA)	Directly inspect power traces for control-flow patterns.
Differential Power Analysis (DPA)	Divide traces and use statistics to recover key bits.
Correlation Power Analysis (CPA)	Correlate measured power with a leakage model.

Differential and Correlation Power Analysis

Key Idea: Data-dependent power usage allows us to model power usage through correlation.

We attack the SubBytes step of AES

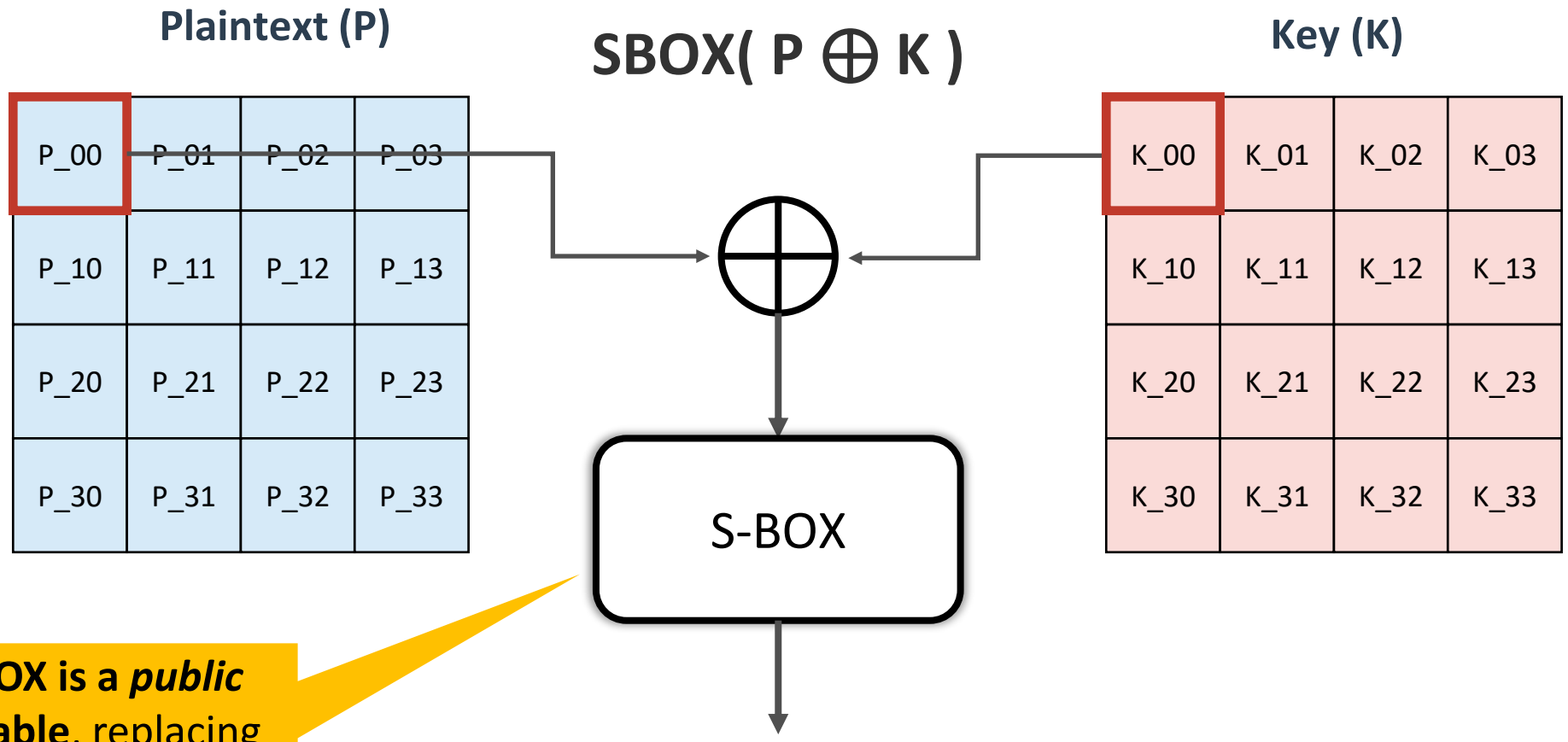


What leaks here?

The SubBytes computes
Operation:
1. Mix Key: $P \oplus K$
2. Substitute: $SBox(P \oplus K)$

The power consumption leaks information about the result of the XOR, directly influenced by the key bytes!

SubBytes performs a linear operation on the key



The S-BOX is a *public* lookup table, replacing each byte in (P ⊕ K) with a fixed value.

Differential and Correlation Power Analysis

Key Idea: We can guess a key byte and check whether power traces confirm our guess.

Differential and Correlation Power Analysis

How can verify a key guess?

Differential Power Analysis: Through dividing the traces and observing differences

Correlation Power Analysis: Through correlation with a statistical model.

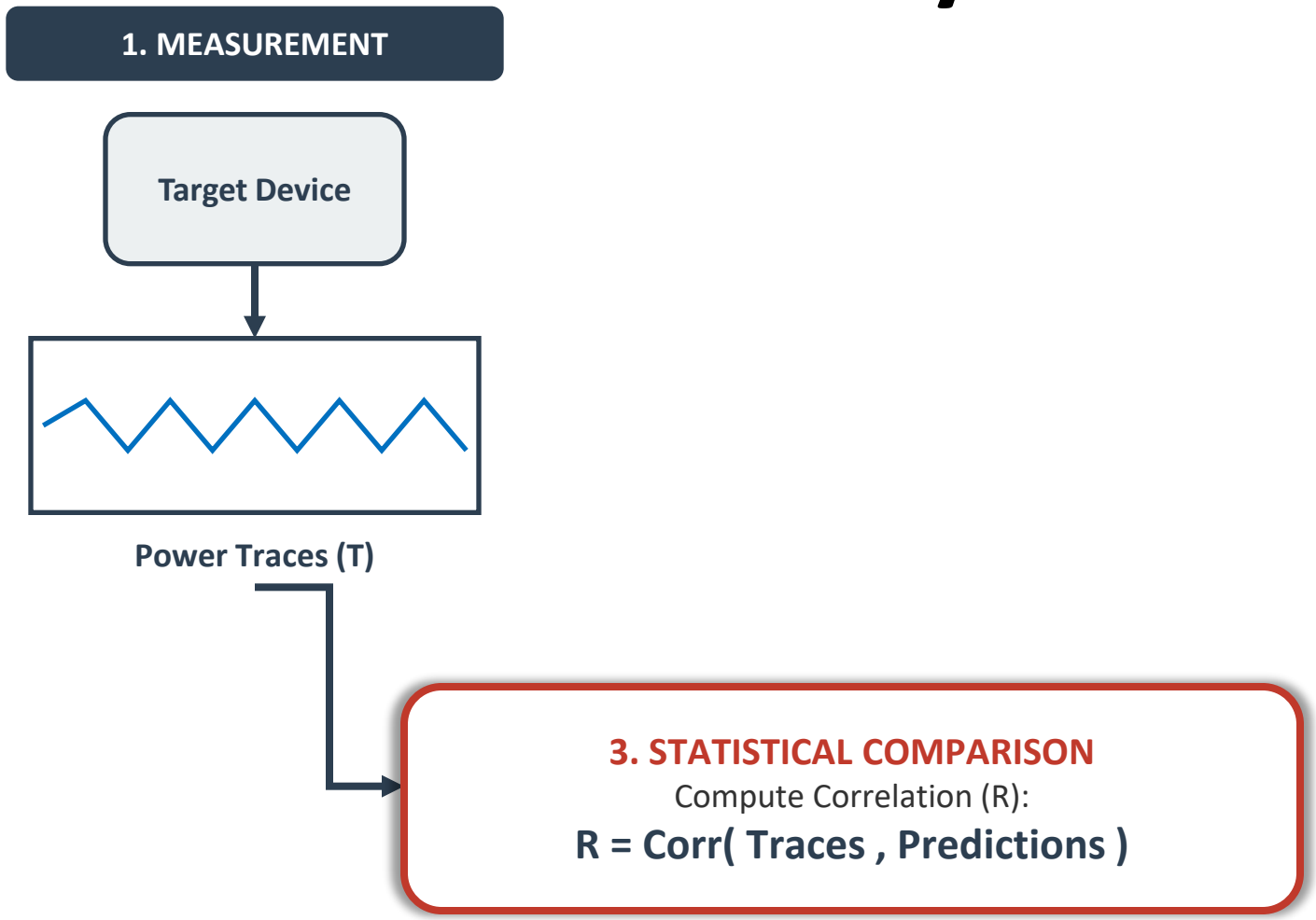
Correlation Power Analysis

Correlation Power Analysis: Use correlation to measure how well estimated power consumption matches measures consumption for each keybyte guess.

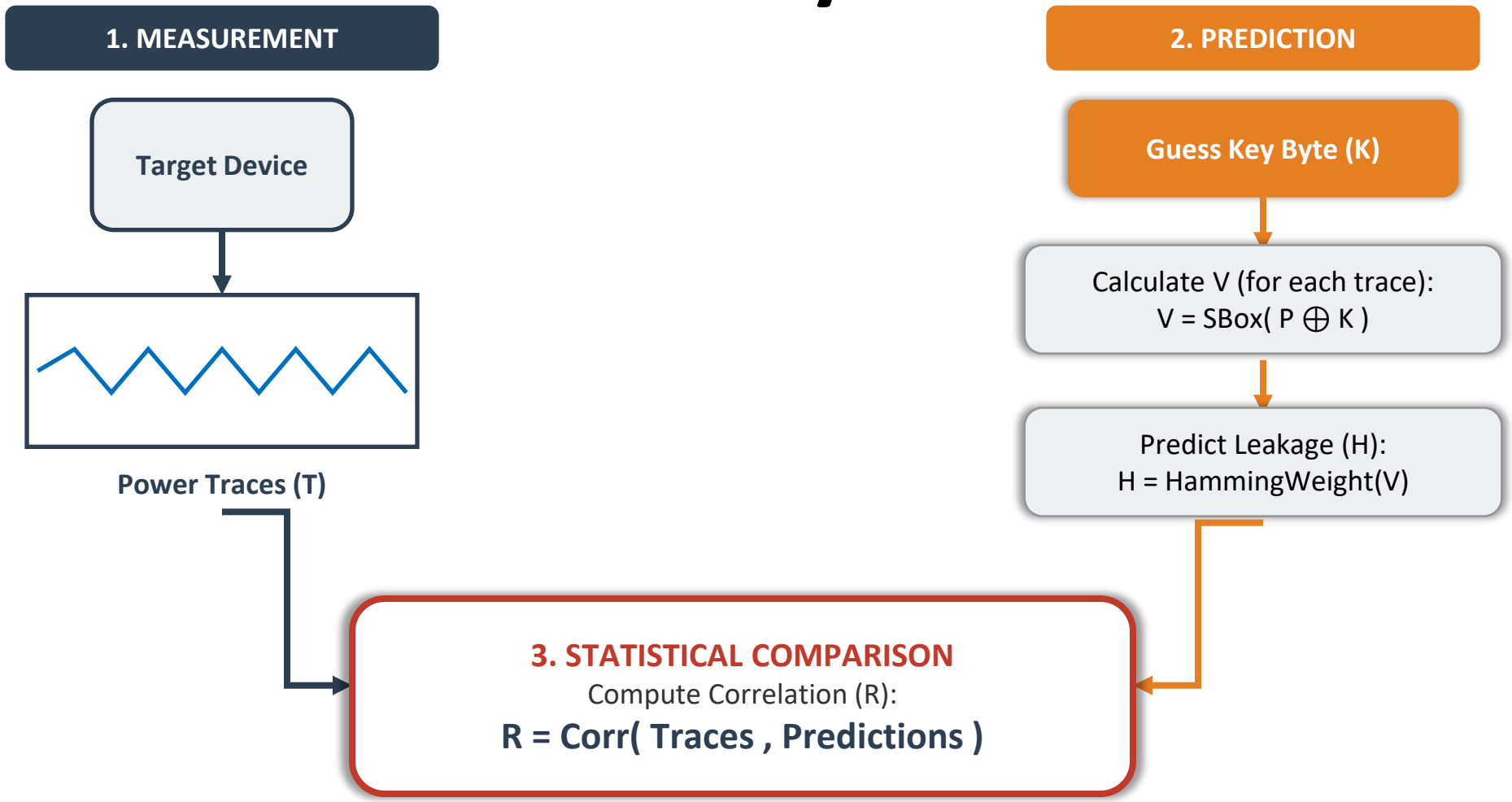
Two dominant leakage models:

- **Hamming Weight**: Power consumption is proportional to the number of 1s in a given value.
- **Hamming Distance**: Power is proportional to the number of “bit flips” between two consecutive values.

Correlation Power Analysis Workflow



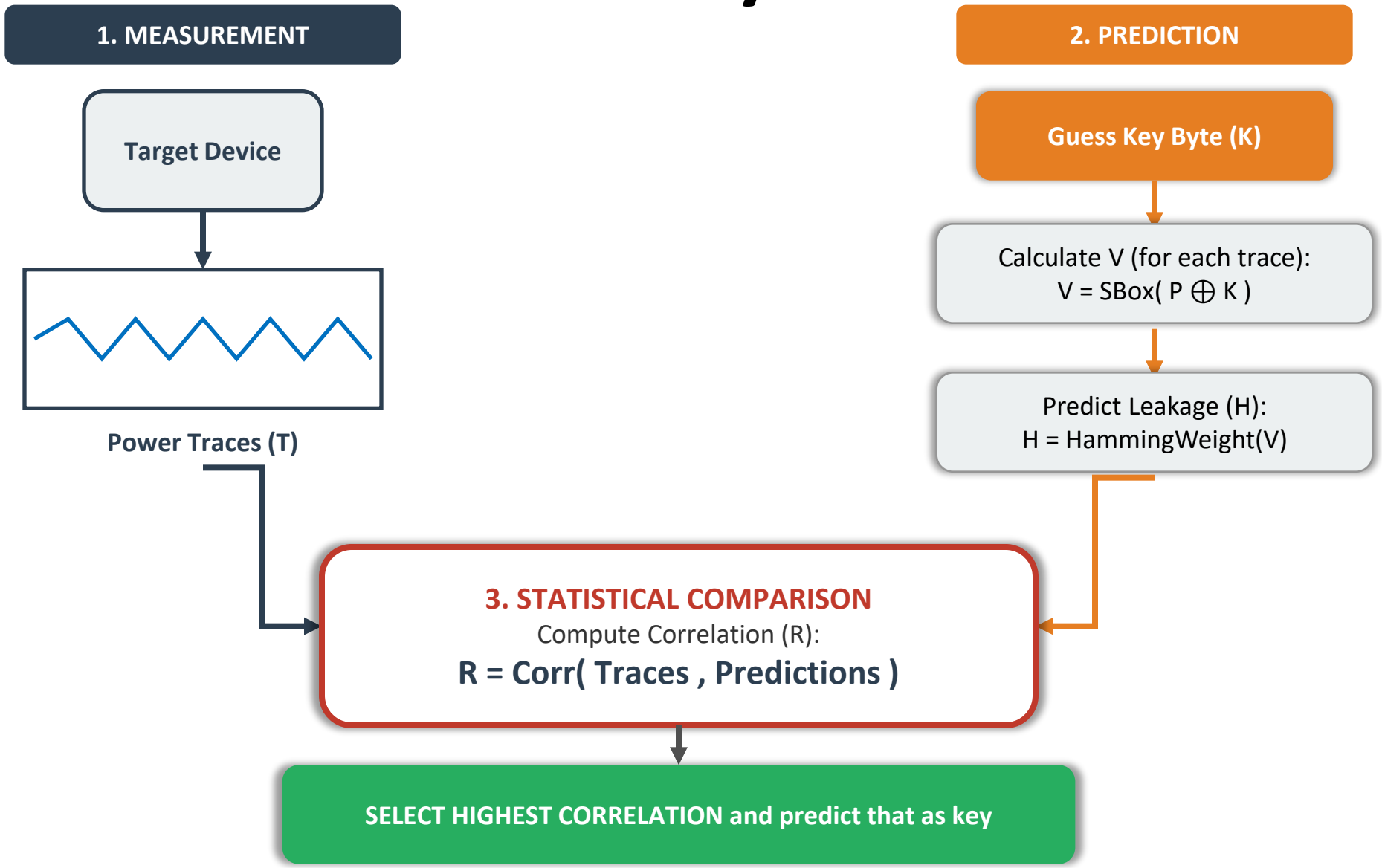
Correlation Power Analysis Workflow



Correlation Power Analysis

- If the key guess is wrong, then what should the correlation be?
- If it is right (and power model is right), what should the correlation be?

Correlation Power Analysis Workflow



For Your Reference: CPA Pseudocode

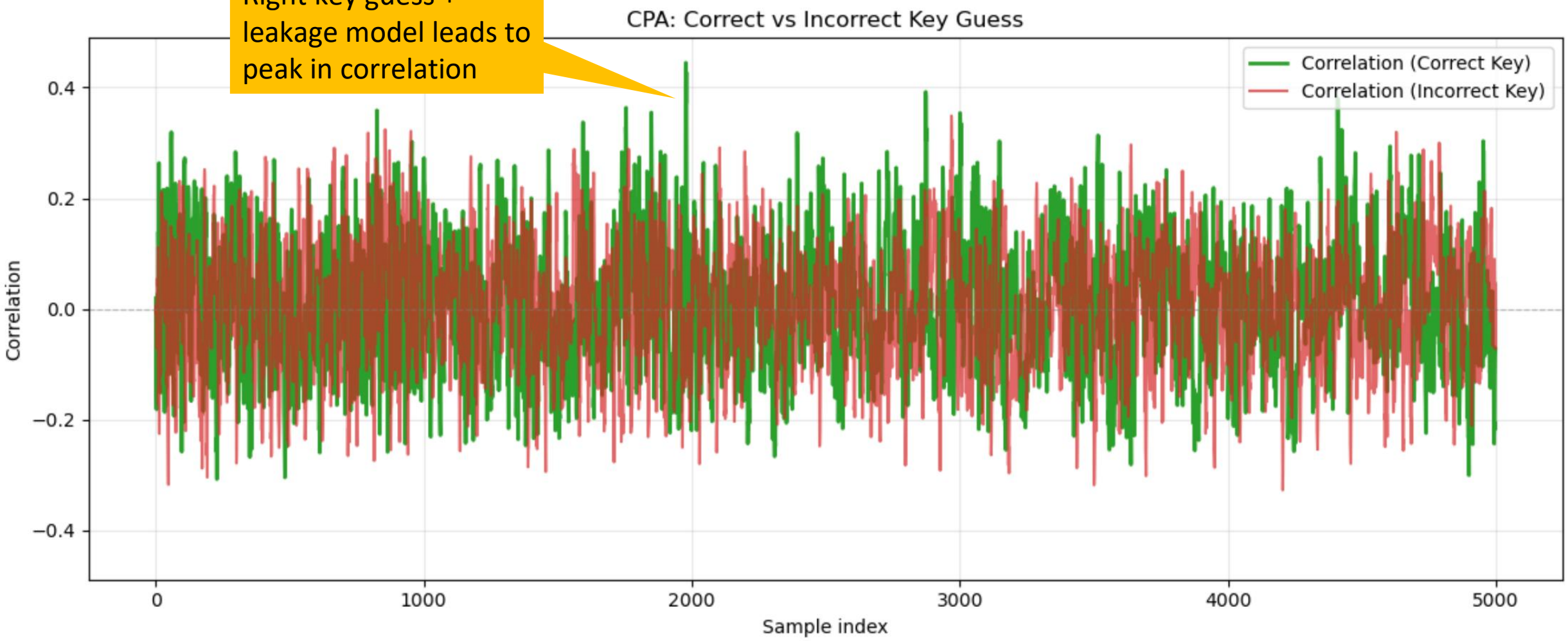
```
INPUT: Set of N plaintexts M[1...N], N power traces T[1...N]
OUTPUT: Correct key byte guess K_final

1. [MEASUREMENT] Acquire power traces T while device encrypts M.
2. [PREDICTION] For each key byte hypothesis k (0 to 255):
     For each trace i (1 to N):
       a. Intermediate Value: v[i,k] = SBox(M[i] XOR k)
       b. Leakage Prediction: H[i,k] = HammingWeight(v[i,k])

3. [STATISTICAL COMPARISON] For each key hypothesis k:
     a. R[k] = CorrelationCoefficient(T[1...N], H[1...N, k])

4. [KEYGUESS] Find k that maximizes |R[k]|:
     K_final = argmax_k( |R[k]| )
```

Right key guess + leakage model leads to peak in correlation



Countermeasures: Hiding and Masking

Hiding: Break correlation between power consumption and performed operations/processed values.

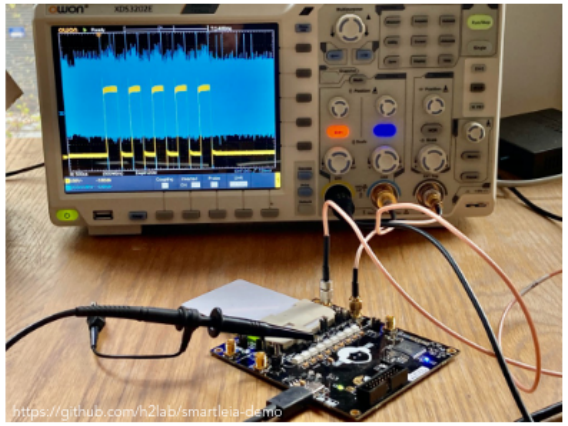
- Examples: Add jitter, randomize clock frequency or execution timing, dual-rail pre-charge logic
  - Can sometimes be broken by advanced attack techniques.

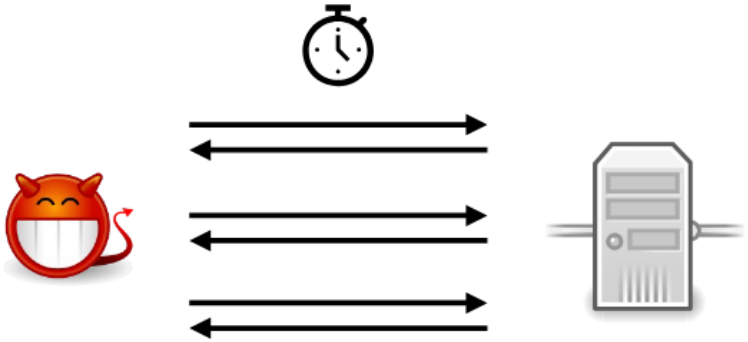
Masking: Remove data-dependence on an algorithm level.

- Split secret x into uniformly random shares $x = x_1 \oplus x_2 \oplus x_3$ and then compute on those shares.
- Expensive, but gives provable guarantees.

You can also exploit power side-channel attacks remotely

Power Side-Channel Attacks → Remote Timing Attacks





Hertzbleed: exploiting dynamic frequency scaling (DVFS)

Power consumptions influences CPU frequency…

and CPU frequency influences speed…

-> We can measure CPU frequency by proxy, remotely!

Key Takeaways

- Physical attacks can be used to break otherwise secure implementations by injecting faults or exploiting leaks through various side-channels
- Many means to achieve this primitive, with the most expensive giving extremely fine-grained control
- Protections are possible, but expensive

Do a UROP with me!

Currently offering two super-urop projects: **viniul@mit.edu**

Many more references

DEF CON 32 -Your Smartcard is Dumb A Brief History of Hacking Access Control Systems - Chad Shortman
https://www.youtube.com/watch?v=zBP2deuPQTg

Breaking Korea Tansit Card with Side-Channel Analysis Attack
https://blackhat.com/docs/asia-17/materials/asia-17-Kim-Breaking-Korea-Transit-Card-With-Side-Channel-Attack-Unauthorized-Recharging-wp.pdf

Cheap Laser Fault Injection: https://www.netspi.com/blog/technical-blog/hardware-and-embedded-systems-penetration-testing/rayv-lite-open-source-laser-injection-tool/

https://blackhat.com/us-24/briefings/schedule/#laser-beams-38-light-streams-letting-hackers-go-pew-pew-building-affordable-light-based-hardware-security-tooling-39708